

ORISO DSFA v5-draft · DE · 2026-09-30

UNAPPROVED / NICHT FREIGEgeben — Nicht freigegebener Prüferentwurf. Quellaussagen und beispielhafte Betreiberwerte benötigen versionsgenaue technische, Betreiber- und juristische Prüfung. Anlage 2 liegt nicht vor.

Kapitel 1

Einleitung, Scope und Stammdaten

Organisatorischer Teil — vom Plattformbetreiber gepflegt (Vertragsunterlagen) — Stammdaten aus dem Administrationsbereich —

Die Plattform ist ein Angebot des Betreibers und seiner angeschlossenen Träger. Die Verarbeitung erfolgt in gemeinsamer Verantwortlichkeit (§ 28 KDG / Art. 26 DSGVO). Gegenstand dieser DSFA ist ausschließlich die Verarbeitung durch den Plattformbetreiber: Bereitstellung und technischer Betrieb der Online-Beratungsplattform (nachfolgend „Plattform“).

1.1 Verantwortlicher

| Verantwortlicher | Deutscher Caritasverband e. V.

| Anschrift | Karlstraße 40, 79104 Freiburg im Breisgau

| Kontakt | datenschutz@caritas.example · +49 761 200-0

| Datenschutzbeauftragte:r | Stabsstelle Datenschutz

| Zuständige Aufsicht | Diözesandatenschutzbeauftragte:r / Landesbeauftragte:r für Datenschutz — Katholisches Datenschutzzentrum Frankfurt, Hausener Weg 66, 60489 Frankfurt am Main

1.2 Anlagen

Anlage 1 — Risikoanalyse (Auszug in Kapitel 10) · Anlage 2 — Löschkonzept (beide Anlagen werden als eigenständige, gleichartig versionierte Teildokumente geführt; Stand dieser Fassung: in Vorbereitung)

1.3 Wiederholung

Diese DSFA wird routinemäßig überprüft, nächster Termin: 01.06.2027. Die Überprüfungshistorie entspricht der Dokumentenhistorie (siehe Versionsblock); jede Version bleibt unter ihrer Versions-URL abrufbar, latest verweist auf den aktuellen Stand.

Kapitel 2

Schwellwertanalyse

Ergebnis DSFA erforderlich — durchgeführt

Vorfragen Ist die Verarbeitung in der Liste der Verarbeitungsvorgänge aufgeführt, für die die zuständige Aufsicht eine DSFA zwingend vorsieht („Muss-Liste“)? § 35 Abs. 5 KDG / Art. 35 Abs. 4 DSGVO
Nein Ist ein Regelbeispiel erfüllt, bei dem das Gesetz ein hohes Risiko vermutet? § 35 Abs. 4 KDG / Art. 35 Abs. 3 DSGVO
Ja

Prüffragen (WP-248-Kriterien) — DSFA erforderlich, wenn zwei oder mehr bejaht werden Werden betroffene Personen bewertet oder eingestuft (Scoring, Profiling)?Nein Erfolgen automatisierte Entscheidungen mit rechtlicher Wirkung oder ähnlich erheblicher Beeinträchtigung?Nein Findet eine systematische Überwachung betroffener Personen statt?Nein Werden vertrauliche, höchstpersönliche oder besondere Kategorien personenbezogener Daten verarbeitet?Ja Erfolgt die Verarbeitung in großem Umfang?Ja Werden Datensätze abgeglichen oder zusammengeführt?Nein Sind schutzbedürftige betroffene Personen betroffen bzw. wirken mehrere Verantwortliche zusammen?Ja Werden innovative Technologien in neuartiger Weise eingesetzt?Nein Führt die Verarbeitung dazu, dass betroffene Personen an der Ausübung eines Rechts gehindert werden?Nein Erfolgt die Verarbeitung an öffentlich zugänglichen Orten?Nein

Eine DSFA ist durchzuführen: Es sind besondere Kategorien personenbezogener Daten § 11 KDG / Art. 9 DSGVO zu erwarten, die Plattform richtet sich an eine große Zahl teils besonders schutzbedürftiger Ratsuchender, und mehrere Verantwortliche wirken zusammen.

Technischer Teil — von ORISO gepflegt — Ergebnisabsatz 2.3 ist organisatorisch —

Vor der Durchführung einer Datenschutz-Folgenabschätzung (nachfolgend „DSFA“) ist zu prüfen, ob die Verarbeitungstätigkeit voraussichtlich ein hohes Risiko für die Rechte und Freiheiten natürlicher Personen zur Folge hat und die DSFA damit nach § 35 KDG / Art. 35 DSGVO verpflichtend ist. Die Prüfung erfolgt zweistufig: zunächst über die beiden Vorfragen (Muss-Liste der zuständigen Aufsicht sowie Regelbeispiele), sodann anhand der zehn Prüffragen, die den Kriterien der Arbeitsgruppe nach Art. 29 (WP 248) entsprechen.

2.1 Vorfragen

Das Regelbeispiel ist erfüllt, weil die Verarbeitung besondere Kategorien personenbezogener Daten im Sinne des § 11 KDG / Art. 9 DSGVO — insbesondere Gesundheitsdaten, Angaben zum Sexualleben, zur religiösen oder weltanschaulichen Überzeugung — in erheblichem Umfang zum Gegenstand hat und sich zugleich an einen teilweise besonders schutzbedürftigen Personenkreis richtet.

Hinweis zum Compliance-Preset. Unter der Datenschutz-Grundverordnung verläuft der Herleitungspfad abweichend: Eine Online-Beratung mit Krisen- und Gesundheitsbezug über digitale Kanäle ist regelmäßig bereits in den Muss-Listen der zuständigen Landesdatenschutzbehörden aufgeführt, sodass die erste Vorfrage dort zu bejahen ist. Das Ergebnis der Schwellwertanalyse bleibt in beiden Regimen dasselbe; nur die Begründungskette wechselt.

2.2 Prüffragen

Es gilt die Entscheidungsregel: Werden zwei oder mehr Fragen bejaht, ist die Durchführung einer DSFA erforderlich.

Zu Frage 4. Gegenstand der Beratung sind ihrer Natur nach vertrauliche Inhalte; je nach Fachbereich sind Gesundheitsdaten, Angaben zu Suchtmittelgebrauch, Schwangerschaft, familiärer Gewalt oder Suizidalität zu erwarten. Der Erhebungsumfang wird je Fachbereich über die Konfiguration der Beratungsart gesteuert (unter anderem Alter, Geschlecht, Bundesland, Suchtmittel, Beratungsanlass); die Plattform speichert diese Angaben strukturiert neben der Beratungssitzung. Ergänzend werden mit den Beratungsthemen kategorisierende Angaben verarbeitet, die für sich genommen bereits einen Rückschluss auf den Beratungsanlass zulassen.

Zu Frage 5. Die Plattform ist als mandantenfähiges Angebot für eine Vielzahl von Trägern, Beratungsstellen und Fachbereichen ausgelegt; die Zahl der registrierten Ratsuchenden, der Beratungsstellen und der aktiven Beratenden ist in Kapitel 3 mit Stichtag ausgewiesen. Bereits die Größenordnung der erreichten Personen spricht für ein erhöhtes Risiko.

Zu Frage 7. Es wirken mehrere Verantwortliche zusammen (Plattformbetreiber, Träger und Beratungsstellen, vgl. Kapitel 5). Zugleich richten sich einzelne Fachbereiche ausdrücklich an schutzbedürftige Personengruppen, insbesondere an Minderjährige und junge Erwachsene sowie an Personen in akuten Krisen- und Abhängigkeitslagen.

Zu Frage 8 — Abgrenzung. Die eingesetzten Verfahren (Matrix-Protokoll mit Olm-/Megolm-Ende-zu-Ende-Verschlüsselung, WebRTC-Videokommunikation über eine selbst betriebene Medienvermittlung, zentrales Identitätsmanagement) sind etablierte, quelloffene und in breitem Einsatz befindliche Standardverfahren. Sie werden hier nicht in neuartiger Weise, sondern bestimmungsgemäß verwendet; die Frage wird daher verneint. Ihr Einsatz wirkt risikomindernd und ist in Kapitel 6 im Einzelnen beschrieben.

Zu Frage 3 — Abgrenzung. Eine systematische Überwachung findet nicht statt: Es werden weder Tracking- oder Analysedienste noch Werbenetzwerke, externe Schriftarten oder Drittanbieter-Skripte eingesetzt; im Browser der Nutzer:innen wird keinerlei Produkt- oder Fehlertelemetrie erhoben. Ehrlichkeitshalber ist gleichwohl festzuhalten, dass die Plattform betriebsbedingt Verhaltens- und Anwesenheitsmetadaten verarbeitet — Lesezeitpunkte von Benachrichtigungen, Online-Status (Presence) im Chat-Dienst, Lesebestätigungen und Aktivitätszeitpunkte —, ohne dass diese zu einer Bewertung oder Überwachung einzelner Personen zusammengeführt würden. Die betreffenden Verarbeitungen und die vorgesehenen Minimierungsmaßnahmen sind in den Abschnitten 6.10, 6.12 und 6.14 dargestellt.

2.3 Ergebnis

Drei der zehn Prüffragen sind zu bejahen; damit ist die Schwelle der Entscheidungsregel überschritten. Eine DSFA ist durchzuführen. Maßgeblich sind die zu erwartenden besonderen Kategorien personenbezogener Daten nach § 11 KDG / Art. 9 DSGVO, der große Umfang der Verarbeitung sowie das Zusammenwirken mehrerer Verantwortlicher bei einem teilweise besonders schutzbedürftigen Personenkreis. Die vorliegende DSFA setzt diese Pflicht um.

Der Ergebnisabsatz ist zugleich der Ort, an dem der Betreiber seine eigene Bewertung des verbleibenden Risikos festhält; die betreiberspezifische Fassung wird über den Freitext-Slot resultParagraph gepflegt.

Organisatorischer Teil — vom Plattformbetreiber gepflegt (Vertragsunterlagen) — Bearbeitung im Administrationsbereich folgt —

Dieser Abschnitt beschreibt die Organisation, die Entscheidungswege und die juristische Abwägung des Trägers. Er ist aus Quellcode nicht ableitbar und wird deshalb nicht von ORISO gepflegt. Bis der Träger ihn verfasst, trägt das Dokument hier nur den eingeklappten Entwurfstext; die eckigen Klammern darin sind bewusst offene Stellen.

Entwurfstext einblenden

Drei der zehn Prüffragen sind zu bejahen; die Schwelle ist damit überschritten und eine Datenschutz-Folgenabschätzung ist durchzuführen. Tragend sind die zu erwartenden besonderen Kategorien personenbezogener Daten nach § 11 KDG / Art. 9 DSGVO, der große Umfang der Verarbeitung — zum Stichtag [Datum] [Zahl] registrierte Ratsuchende in [Zahl] Beratungsstellen — sowie das Zusammenwirken mehrerer Verantwortlicher bei einem teilweise besonders schutzbedürftigen Personenkreis. [Ergänzende Bewertung des Verantwortlichen, z. B. zur Risikoeinstufung oder zu Besonderheiten einzelner Fachbereiche.] Die vorliegende DSFA setzt diese Pflicht um; ihr Ergebnis ist in Kapitel 10 festgehalten.

Kapitel 3

Kontext und Kennzahlen

Organisatorischer Teil — vom Plattformbetreiber gepflegt (Vertragsunterlagen) — Kennzahlen aus dem Administrationsbereich —

Die Plattform verbindet Online- und Vor-Ort-Beratung (Blended Counseling). Der Zugang ist browserbasiert; das Leistungsspektrum umfasst Nachrichten und Dateien, Sprachnachrichten, Gruppenchats, Video-Beratung und einen anonymen Live-Einzelchat.

12 Träger

148 Beratungsstellen

412 aktive Beratende

9.640 registrierte Ratsuchende

Stichtag: 01.08.2026 · In die Kennzahlen fließen ausschließlich Aggregatzahlen ein — keine Fall- oder Personendaten.

Kapitel 4

Akteure, Rollen und Governance

Technischer Teil — von ORISO gepflegt — Abschnitt 4.5 ist organisatorisch —

Partner, Träger und Betreiber entscheiden gemeinsam über Zwecke und Mittel der Verarbeitung; es besteht eine Vereinbarung über die gemeinsame Verantwortlichkeit (§ 28 Abs. 1 S. 2 KDG / Art. 26 Abs. 1 DSGVO). Träger und Beratungsstellen bleiben für die fachliche Beratung verantwortlich, einschließlich der Falldokumentation außerhalb der Plattform. Die Plattform bildet den Abschluss der Auftragsverarbeitungsvereinbarungen mit den Trägern digital ab; Träger-Vertreter:innen unterzeichnen über personalisierte, tokenisierte Links, ohne selbst Nutzer:innen der Beratungsanwendung zu sein.

[Governance-Beschreibung des Betreibers: Kooperationsstruktur, Gremien, Entscheidungswege — betreiberspezifischer Freitext]

4.1 Auftragsverarbeiter und Empfänger

Tabelle bei schmalen Viewports horizontal scrollbar

| Name | Tätigkeit | Standort | Gemeinsam Verantwortlich | Auftragsverarbeiter | AVV

| Beratungsstellen bzw. Träger | Fachliche Beratung | Deutschland | Ja | Nein | Nein

| neusta integrate GmbH | Server-Hosting, Betrieb der Produktivumgebung | Deutschland | Nein | Ja | Ja

| GS Design GmbH Kreuzbergstr. 30 VH, 10965 Berlin | Entwicklung, Wartung, Support | Deutschland | Nein | Ja | Ja

| Greyt.IT UG Richardstr. 11, 12043 Berlin — Subunternehmen der GS Design GmbH | Technische Entwicklung | Deutschland | Nein | Ja | Ja

Von den Entwicklungsarbeitsplätzen besteht kein Zugriff auf personenbezogene Produktivdaten; Entwicklung und Test arbeiten ausschließlich mit synthetischen Daten. Produktivbetrieb und Administration liegen beim Betriebsdienstleister im Rechenzentrum (Anhang 3 zum Auftragsverarbeitungsvertrag, Stand 14.08.2026).

4.2 Rollen und Berechtigungen

Die Plattform kennt vier Personalebenen und die anonyme ratsuchende Person. Intern bilden vierzehn Keycloak-Realm-Rollen die feingranularen API-Rechte ab. Zwei Regeln gelten durchgängig: hierarchische Isolation — kein Träger sieht einen anderen, keine Beratungsstelle sieht Ratsuchende oder Beratende einer anderen — und Vererbung der Rechtstexte: Impressum,

Datenschutzerklärung und Einwilligungstext bestehen auf jeder Ebene; ohne eigene Fassung gilt die der übergeordneten Ebene.

Plattform-Admin

Betreibt die Plattform, legt Träger an und pflegt die Rechtstext-Vorlagen der Plattform-Ebene. Kann Chat-Inhalte technisch nicht einsehen.

user-admin2FA Pflicht

Träger-Admin

Verantwortet einen Träger: legt Beratungsstellen und deren Administration an, pflegt die Rechtstexte der Träger-Ebene. Von anderen Trägern vollständig isoliert.

tenant-adminsingle-tenant-admin2FA Pflicht

Beratungsstellen-Admin

Leitet eine Beratungsstelle: lädt Beratende ein, konfiguriert Live-Chat-Link, Themen und PLZ-Zuordnung, kann die Rechtstexte der eigenen Stelle überschreiben.

agency-adminrestricted-agency-adminrestricted-consultant-admin

Beratende:r

Nimmt Anfragen aus dem Warteraum an (älteste zuerst) und führt die verschlüsselte Beratung. Supervision ist eine Funktion an dieser Rolle, keine eigene Rolle.

consultantgroup-chat-consultantsupervisor-consultant

Ratsuchende:r (anonym) — betritt den Warteraum ohne Registrierung unter einem systemgenerierten Pseudonym; Keycloak-Rolle anonymous. Erhoben werden nur Pseudonym, kurzlebiges Sitzungs-Cookie, Warteschlangenposition und das über den Link gewählte Thema. Beim Verlassen werden Pseudonym und Raum automatisiert entfernt. Die Rolle user ist für einen künftigen registrierten Ablauf reserviert.

4.3 Berechtigungsmatrix

Tabelle bei schmalen Viewports horizontal scrollbar

| Fähigkeit | Plattform-Admin | Träger-Admin | Stellen-Admin | Beratende:r | Ratsuchende:r

| Träger anlegen | Ja | Nein | Nein | Nein | Nein

| Beratungsstellen anlegen | Nein | Ja | Nein | Nein | Nein

| Beratende anlegen / einladen | Ja | Ja | Ja | Nein | Nein

| Daten des eigenen Trägers sehen | n/a | Ja | nur eigene Stelle | nur eigene Stelle | Nein

| Daten anderer Träger sehen | Nein | Nein | Nein | Nein | Nein

| Rechtstexte Plattform-Ebene bearbeiten | Ja | Nein | Nein | Nein | Nein

| Rechtstexte Träger-Ebene bearbeiten | Nein | Ja | Nein | Nein | Nein

| Rechtstexte Stellen-Ebene bearbeiten | Nein | Ja | Ja | Nein | Nein

| Live-Chat-Links erzeugen | Nein | Ja | Ja | Nein | Nein

| Ticket aus dem Warteraum annehmen | Nein | Nein | Nein | Ja | Nein

| Eigene Live-Chat-Verfügbarkeit schalten | Nein | Nein | Nein | Ja | Nein

| Chat-Inhalte lesen | E2EE | E2EE | E2EE | nur eigene Sitzung | nur eigene Sitzung

| Löschung beim Verlassen | Nein | Nein | Nein | Nein | Ja

| 2FA erzwungen | Ja | Ja | empfohlen | empfohlen | n/a

4.4 Vererbung der Rechtstexte

Plattform-VorlagePlattform-Admin

Träger-FassungTräger-Admin

Fassung der BeratungsstelleStellen-Admin

Wirksamer Text für Ratsuchende

Impressum, Datenschutzerklärung und Einwilligungstext existieren auf jeder Ebene. Pflegt eine Beratungsstelle keine eigene Fassung, gilt die des Trägers; pflegt der Träger keine, gilt die Plattform-Vorlage. Ratsuchende sehen damit immer einen vollständigen Satz Rechtstexte.

4.5 Governance und Entscheidungsgremien

Organisatorischer Teil — vom Plattformbetreiber gepflegt (Vertragsunterlagen) — Bearbeitung im Administrationsbereich folgt —

Dieser Abschnitt beschreibt die Organisation, die Entscheidungswege und die juristische Abwägung des Trägers. Er ist aus Quellcode nicht ableitbar und wird deshalb nicht von ORISO gepflegt. Bis der Träger ihn verfasst, trägt das Dokument hier nur den eingeklappten Entwurfstext; die eckigen Klammern darin sind bewusst offene Stellen.

Entwurfstext einblenden

Die Plattform wird von [Name des Verantwortlichen] gemeinsam mit [Bezeichnung des Verbundes bzw. der Kooperation] betrieben; sie ist ein Angebot an die angeschlossenen Träger und deren Beratungsstellen. Zentrales Steuerungsgremium ist [Name des Gremiums, z. B. Lenkungsausschuss], das sich aus [Zusammensetzung: Anzahl und entsendende Stellen] zusammensetzt und [Turnus, z. B. zweimal jährlich] tagt; es entscheidet über Zwecke und Mittel der Verarbeitung, über Grundsatzfragen und über das Budget. Die operative Geschäftsführung liegt bei [Stelle/Referat], die dem Gremium mindestens [Turnus] berichtet. Fachlich beraten wird das Gremium durch [weitere Gremien, z. B. Fachbeirat Datenschutz, Steuerkreis Technische Entwicklung], deren Aufgaben und Besetzung in [Verweis auf Kooperationsvereinbarung/Geschäftsordnung] geregelt sind. Träger und Beratungsstellen sind rechtlich selbstständige Organisationen; sie sind über [Entsendungs- oder Beteiligungsverfahren] in die Entscheidungsfindung eingebunden.

Kapitel 5

Verantwortlichkeit

Organisatorischer Teil — vom Plattformbetreiber gepflegt (Vertragsunterlagen) — Bearbeitung im Administrationsbereich folgt —

Dieser Abschnitt beschreibt die Organisation, die Entscheidungswege und die juristische Abwägung des Trägers. Er ist aus Quellcode nicht ableitbar und wird deshalb nicht von ORISO gepflegt. Bis der Träger ihn verfasst, trägt das Dokument hier nur den eingeklappten Entwurfstext; die eckigen Klammern darin sind bewusst offene Stellen.

Entwurfstext einblenden

Verantwortlicher im Sinne des § 4 Nr. 9 KDG / Art. 4 Nr. 7 DSGVO ist [Name, Rechtsform, Anschrift]. Die Verarbeitung erfolgt in gemeinsamer Verantwortlichkeit nach § 28 Abs. 1 KDG / Art. 26 DSGVO mit [Aufzählung: Träger, Kooperationspartner]; eine Vereinbarung über die gemeinsame Verantwortlichkeit nach § 28 Abs. 1 S. 2 KDG / Art. 26 Abs. 1 S. 2 DSGVO besteht seit [Datum] und regelt in ihren Anlagen [Nummern] die Zuteilung der Pflichten, insbesondere die

Erfüllung der Betroffenenrechte und der Informationspflichten. Die Träger bleiben für die fachliche Beratung einschließlich der Falldokumentation außerhalb der Plattform verantwortlich. Als Auftragsverarbeiter nach § 29 KDG / Art. 28 DSGVO sind eingebunden: [Name des Hosting-Betreibers] für Betrieb und Hosting der Produktivumgebung sowie [Name des Entwicklungs-/Supportdienstleisters] für Entwicklung, Wartung und Support; mit beiden bestehen Auftragsverarbeitungsvereinbarungen, der Verarbeitungsort ist [Land]. Die Datenschutzbeauftragung nimmt [Name, Organisation, Kontakt] wahr; zuständige Aufsicht ist [Name und Anschrift der Aufsichtsbehörde].

Kapitel 6

Verfahren und Technik

E2EE Olm / Megolm TLS-Transportverschlüsselung 2FA für Beratende Anonyme Konten
zeitgesteuert gelöscht

Technischer Teil — von ORISO gepflegt —

6.1 Zweck

Zweck der Verarbeitung ist die Bereitstellung und der technische Betrieb einer Online-Beratungsplattform (nachfolgend „Plattform“), über die Träger und Beratungsstellen ihren fachlichen Beratungsauftrag digital, ortsunabhängig und niedrigschwellig erfüllen können. Die inhaltliche Beratung selbst sowie deren Fachdokumentation verantworten die Träger; eine inhaltliche Falldokumentation findet auf der Plattform nicht statt. Beratungsinhalte werden Ende-zu-Ende-verschlüsselt übertragen und gespeichert (im Einzelnen Abschnitt 6.9).

6.2 Beratungsarten

6.2.1 Einzelberatung (1:1-Chat)

Registrierte Ratsuchende richten ihre Erstanfrage an eine Beratungsstelle; die Zuordnung erfolgt über die angegebene Postleitzahl sowie das gewählte Beratungsthema. Der Beratungsverlauf findet in einem eigenständigen, nicht öffentlich auffindbaren, Ende-zu-Ende-verschlüsselten Chatraum statt; Beratung ist sowohl synchron als auch asynchron möglich. Der Zugriff einer weiteren beratenden Person auf einen bestehenden Fall ist ausschließlich über das protokollierte Übergabeverfahren vorgesehen (Abschnitt 6.13).

6.2.2 Anonymer Live-Einzelchat

Der Live-Einzelchat ist ohne Registrierung nutzbar. Die ratsuchende Person betritt einen virtuellen Warteraum unter einem systemgenerierten Pseudonym; personenbezogene Angaben werden nicht erhoben. Auch dieser Chat ist Ende-zu-Ende-verschlüsselt. Anonyme Konten werden nach Inaktivität automatisiert deaktiviert und anschließend gelöscht (Abschnitt 6.18).

6.2.3 Gruppenchat

Der Gruppenchat ermöglicht moderierte n:n-Beratung, insbesondere für Selbsthilfeformate. Die Moderation legt Chatangebote mit Thema, Datum, Uhrzeit sowie einmaliger oder wiederkehrender Terminfolge an; abgelaufene Gruppenchats werden automatisiert deaktiviert. Auch Gruppenräume werden mit aktivierter Ende-zu-Ende-Verschlüsselung angelegt.

Risiko und Kompensation. In einer Gruppe nehmen die Teilnehmenden einander wahr; die Vertraulichkeit gegenüber anderen Ratsuchenden beruht damit auf der Pseudonymität und auf der Moderation, nicht auf technischer Trennung. Kompensierend wirken die systemgenerierten Pseudonyme (Abschnitt 6.3), die Moderationsrechte einschließlich des Entfernens von Teilnehmenden sowie die Beschränkung der Teilnehmendenzahl. Eine wiederkehrende Terminserie kann für sich genommen ein Teilnahmeprofil erkennen lassen; dieses Restrisiko ist im Rahmen der Moderation und der Aufklärung der Teilnehmenden zu adressieren.

6.2.4 Video- und Audio-Beratung

Die Videoberatung erfolgt browserbasiert über eine selbst betriebene Medienvermittlung; sie ist in Abschnitt 6.10 gesondert beschrieben.

6.2.5 Sprachnachrichten

Sprachnachrichten sind in allen Chat-Formen möglich und je Träger und Chat-Typ abschaltbar; sie sind wegen ihres besonderen Risikoprofils in Abschnitt 6.11 gesondert beschrieben.

6.2.6 Terminverwaltung nicht ausgeliefert

Eine Terminverwaltung im Sinne eines Kalender- oder Buchungsmoduls ist nicht Bestandteil des aktuellen Leistungsumfangs. Ein entsprechendes Modell ist als Architekturentscheidung beschrieben (ADR-020, „Scheduled calls, secure invitations, and a unified contact calendar“, Status „Accepted“); ausgeliefert ist davon bisher nichts. Ein im Datenmodell vorhandener Termin-Datensatz stammt aus der Vorgängerplattform und ist im Auslieferungsstand nicht aktiviert. Diese DSFA bewertet die geplante Funktion daher nicht; sie ist bei Auslieferung zu ergänzen.

6.3 Registrierung, Anonymität und Pseudonymität der Ratsuchenden

Die Registrierung ist ohne Angabe identifizierender Daten möglich. Der Benutzername wird systemseitig erzeugt (Kombination aus Adjektiv, Tierbezeichnung und Namensbestandteil, ergänzt um eine Avatarfarbe); ein frei gewählter, potenziell identifizierender Klarname ist konstruktionsbedingt ausgeschlossen. Dies ist eine bewusste Verbesserung gegenüber der Vorgängerplattform, auf der Benutzernamen frei wählbar waren. Pflichtangabe ist die Postleitzahl zur Zuordnung der zuständigen Beratungsstelle; ihre Richtigkeit wird nicht geprüft. Die Angabe einer E-Mail-Adresse ist optional.

Ehrliche Einordnung. Ein systemgeneriertes Pseudonym ist kein anonymes Datum. Es ist über die Kontokennung dauerhaft mit allen Beratungsvorgängen derselben Person verkettbar und daher personenbezogen zu behandeln. Vollständige Anonymität besteht allein im registrierungsfreien Live-Einzelchat, solange die ratsuchende Person keine identifizierenden Angaben von sich aus macht. Ob eine Nutzung anonym ist, ergibt sich damit aus dem gewählten Zugangsweg und dem Kontostatus — sie lässt sich insbesondere nicht aus dem angezeigten Namen ableiten.

Wirksame Datenminimierung, aber begrenzt. Neben der Sitzung werden je nach Fachbereich Angaben gespeichert, die zusammen ein enges Quasi-Identifikator-Set bilden: Postleitzahl, Alter, Geschlecht, Beratungsanlass und Beziehungskonstellation stehen in einer Datenzeile nebeneinander. Für kleine Beratungsstellen ist damit ein Re-Identifikationsrisiko nicht auszuschließen. Kompensierend wirken die Freiwilligkeit der Zusatzangaben, die fachbereichsbezogene Steuerung des Erhebungsumfangs und der Verzicht auf jede Verknüpfung mit externen Datenquellen. Ebenfalls gespeichert wird ein Herkunftsverweis (Referrer) der Registrierung; er ist für die Zwecke der Beratung nicht erforderlich und als Minimierungskandidat auszuweisen.

6.4 Konten der Beratenden, Administration und Einladungsverfahren

Konten für Beratende und für administrative Rollen werden nicht durch die Betroffenen selbst angelegt, sondern über ein Einladungsverfahren durch die Administration des jeweiligen Trägers bzw. der Beratungsstelle. Verarbeitet werden dabei Vor- und Nachname, die dienstliche E-Mail-Adresse, die Zielrolle sowie die Zuordnung zu Träger und Beratungsstelle. Die Einladung wird per E-Mail mit einem zeitlich befristeten, kryptografisch gesicherten Link zugestellt; der Zugriffsschlüssel wird nur als Hashwert gespeichert.

Bei Beratenden handelt es sich um Klarnamen; der Anzeigename im Chat-Dienst entspricht dem Realnamen, während Ratsuchende ausschließlich unter ihrem Pseudonym erscheinen. Ein Bulk-Import einzuladender Personen aus einer Datei ist möglich; in diesem Fall stammen die Daten nicht von der betroffenen Person selbst, weshalb die Informationspflicht bei Erhebung bei Dritten nach § 16 KDG / Art. 14 DSGVO durch den einladenden Träger zu erfüllen ist.

Restrisiko. Der Versandvorgang wird mit einer vollständigen Kopie der versendeten Nachricht einschließlich Empfängeradresse archiviert; eine Aufbewahrungsfrist ist bislang nicht definiert. Ebenso ist für abgelaufene, nicht angenommene Einladungen kein Löschlauf eingerichtet. Beide Punkte sind als Löschkonzept-Maßnahmen ausgewiesen (Abschnitt 6.18).

6.5 Authentifizierung, Rollen und Zwei-Faktor-Authentisierung

Die Anmeldung erfolgt über ein zentrales Identitätsmanagement (Keycloak) auf Basis von OAuth 2.0 und OpenID Connect mit signierten Token; Passwörter werden ausschließlich als gesalzene Hashwerte im Identitätsmanagement gespeichert und sind der Anwendung zu keinem Zeitpunkt im Klartext zugänglich. Sämtliche Verbindungen sind transportverschlüsselt.

Rollenmodell. Die Plattform kennt vier Personalebenen sowie die ratsuchende Person; intern bilden feingranulare Realm-Rollen die API-Rechte ab.

| Ebene | Aufgabe | Zugriff auf Beratungsinhalte

| Plattform-Administration | Betrieb der Plattform, Anlage von Trägern, Pflege der Rechtstext-Vorlagen der Plattformebene | nein

| Träger-Administration | Verantwortung für einen Träger: Anlage von Beratungsstellen und deren Administration, Pflege der Rechtstexte der Trägerebene | nein

| Beratungsstellen-Administration | Leitung einer Beratungsstelle: Einladung Beratender, Konfiguration von Themen, Postleitzahlbereichen und Live-Chat-Zugang | nein

| Beratende | Annahme von Anfragen und Führung der verschlüsselten Beratung; Supervision ist eine Funktion an dieser Rolle, keine eigene Rolle | nur eigene Fälle

| Ratsuchende | Nutzung der Beratung | nur eigene Sitzung

Es gelten zwei durchgängige Regeln: hierarchische Isolation — kein Träger sieht einen anderen, keine Beratungsstelle sieht Ratsuchende oder Beratende einer anderen — und Vererbung der Rechtstexte: Impressum, Datenschutzerklärung und Einwilligungstext bestehen auf jeder Ebene; ohne eigene Fassung gilt die der übergeordneten Ebene.

Komposit-Rollen der Administration. Die Anlage einer Träger-Administration vergibt systemseitig ein Bündel mehrerer Rollen (Nutzerverwaltung, Agenturverwaltung, Mandantenverwaltung sowie, außerhalb des Single-Domain-Betriebs, Themenverwaltung). Die Plattform-Administration ist technisch dieselbe Rollenkombination ohne Mandantenbindung; sie ist damit trägerübergreifend lesend umfassend berechtigt. Eine Rolle, die den Betrieb eines Trägers erlaubt, ohne dessen vertrauliche Betriebs- und Beratungsmetadaten einsehen zu können, existiert derzeit nicht. Dieses Restrisiko ist in Abschnitt 6.16 behandelt.

Zwei-Faktor-Authentisierung. Als zweiter Faktor stehen eine Authenticator-Anwendung (TOTP, sechsstelliger Code, 30-Sekunden-Intervall) sowie ein E-Mail-Einmalcode (sechsstellig, Gültigkeit

15 Minuten, höchstens drei Fehlversuche) zur Verfügung. Für Ratsuchende ist die Einrichtung optional. Für alle über das Einladungsverfahren angelegten Konten — insbesondere Träger- und Beratungsstellen-Administration sowie Beratende — ist die Einrichtung verbindlicher Bestandteil der Kontoaktivierung: Das Konto bleibt gesperrt, bis ein zweiter Faktor aktiv ist. Eine Befreiung ist ausschließlich administrativ möglich, setzt die Angabe eines Grundes voraus und wird personenbezogen mit Zeitpunkt und veranlassender Person dokumentiert. Für die Plattform-Administration besteht demgegenüber lediglich eine Aufforderung beim Anmelden, die sitzungsweise zurückgestellt werden kann („später einrichten“) und bei der nächsten Anmeldung erneut erscheint; ein technischer Zwang besteht insoweit nicht.

Ehrliche Grenzbenennung. Die maßgebliche Konfiguration des Identitätsmanagements wird beim Erststart importiert und anschließend zur Laufzeit durch Skripte verändert; keine der im Quellcode versionierten Konfigurationsdateien ist daher für den Live-Zustand autoritativ. Für die abschließende Fassung dieser DSFA ist ein Export des Live-Realms erforderlich. Aus den versionierten Ständen ergibt sich ferner, dass ein automatischer Anmeldeschutz gegen systematisches Durchprobieren (Brute-Force-Sperre) nicht aktiviert ist — was zugleich bedeutet, dass keine Fehlversuchs- und IP-Historie gespeichert wird — und dass die Gültigkeitsdauer von Zugriffstoken mit fünf Stunden großzügig bemessen ist. Eine Passwortrichtlinie (Mindestlänge, Zeichenklassen) ist aus den Repositorien nicht belegbar und darf in dieser DSFA nicht behauptet werden, bevor sie am Live-System nachgewiesen ist.

6.6 Verarbeitung der IP-Adresse und Protokollierung im Transportweg

Die Anwendungsdienste selbst speichern keine IP-Adressen betroffener Personen in ihren Fachdatenbeständen; sie arbeiten mit pseudonymen Kennungen und signierten Token. Für die Weitergabe der Client-IP an die Fachdienste existiert ein Filter mit einem strengen Modus, der den entsprechenden Weiterleitungs-Header entfernt; standardmäßig ist dieser strenge Modus nicht aktiv.

Ehrlich auszuweisen ist, dass IP-Adressen an anderer Stelle des Transportwegs anfallen:

Der vorgelagerte Eingangs-Proxy (Ingress) protokolliert im Standardformat die Client-IP, den aufgerufenen Pfad und die Browserkennung. Ein zentraler Log-Versand ist nicht eingerichtet; die Aufbewahrung folgt der Rotationsvorgabe der Container-Plattform und ist damit nicht ausdrücklich festgelegt.

Das Identitätsmanagement persistiert zwar keine Anmeldeereignisse in seiner Datenbank, schreibt diese aber über den aktiven Protokoll-Zuhörer einschließlich der IP-Adresse in den Server-Log-Strom. Eine IP-freie Variante dieses Zuhörers liegt vor, ist jedoch nicht aktiviert — eine naheliegende und aufwandsarme Härtungsmaßnahme.

Einzelne Endpunkte der Zwei-Faktor-Erweiterung führen den Benutzernamen im URL-Pfad; er gelangt dadurch in die Zugriffsprotokolle der vorgelagerten Komponenten.

Beim Aufbau einer Videoverbindung werden derzeit öffentliche STUN-Server eines US-amerikanischen Anbieters angefragt; dabei werden Client-IP-Adressen an einen Empfänger in einem Drittland übermittelt (Abschnitt 6.10).

Kompensation und Maßnahme. Der Container der Administrationsoberfläche protokolliert bereits bewusst ohne Client-IP; dasselbe Format ist für die übrigen Web-Container vorgesehen. Als Maßnahmen sind festzuhalten: Aktivierung des IP-freien Protokoll-Zuhörers im Identitätsmanagement, Festlegung einer ausdrücklichen Aufbewahrungsfrist für Zugriffsprotokolle, Maskierung tokenhaltiger URL-Parameter in den Zugriffsprotokollen sowie Ersetzung der externen STUN-Server durch eigene Komponenten. Die Aussage der Vorgängerdokumentation, IP-Adressen würden „zu keiner Zeit vom System mitgeschrieben“, ist für diese Plattform in dieser Absolutheit nicht haltbar und wird bewusst nicht übernommen.

6.7 Cookies und Websitenutzungsdaten

Die Plattform verzichtet vollständig auf Tracking, Analysedienste, Werbenetzwerke, externe Schriftarten und Drittanbieter-Skripte; sämtliche Bestandteile werden von der Plattform selbst ausgeliefert. Im Browser der Nutzer:innen wird keine Produkt- oder Fehlertelemetrie an Dritte erhoben. Es werden ausschließlich technisch notwendige Cookies eingesetzt; ein Einwilligungsbanner ist daher nicht erforderlich. Ohne Cookie-Unterstützung ist die Anwendung nicht nutzbar; hierauf wird vor der Anmeldung hingewiesen.

| Cookie | Setzende Stelle | Zweck | Speicherdauer | Attribute

| keycloak | Anwendung | API-Authentifizierung (Zugriffstoken) | Sitzung | SameSite=Strict, Secure

| refreshToken | Anwendung | Erneuerung der Anmeldesitzung | Sitzung | SameSite=Strict, Secure

| CSRF-TOKEN | Anwendung | Schutz vor Cross-Site-Request-Forgery | Sitzung | SameSite=Strict

| lang | Anwendung | Sprachwahl | Sitzung | SameSite=Strict

| useInformal | Anwendung | Du-/Sie-Anrede | Sitzung | SameSite=Strict

| tenantId | Anwendung | Mandantenzuordnung | Sitzung | SameSite=Strict

| ui-version | Anwendung | Wahl der Oberflächenversion | befristet (Ablaufdatum) | SameSite=Lax

| matrix_sso_user_id, matrix_sso_access_token, matrix_sso_device_id, matrix_sso_hs_url | Anwendung | Übergabe der Chat-Sitzung beim Wechsel der Oberflächenversion | Sitzung | SameSite=Lax, Secure

| oriso-admin.language | Administrationsoberfläche | Sprachwahl | befristet | —

| AUTH_SESSION_ID, KEYCLOAK_IDENTITY, KEYCLOAK_SESSION, KC_RESTART, KEYCLOAK_LOCALE, KC_AUTH_STATE (jeweils ggf. _LEGACY) | Identitätsmanagement | Single-Sign-on-Sitzung | an die Sitzungslaufzeiten des Realms gebunden | HttpOnly, Secure

Restrisiko. Die beiden Authentifizierungs-Cookies der Anwendung sind nicht mit dem Attribut HttpOnly versehen und werden zusätzlich im lokalen Speicher des Browsers gespiegelt; sie sind damit für Skripte im Seitenkontext lesbar. Die Cookies zur Übergabe der Chat-Sitzung tragen zudem ein Matrix-Zugriffstoken bei gelockertem SameSite-Attribut. Beides erhöht die Auswirkung einer erfolgreichen Cross-Site-Scripting-Attacke und ist als Härungsmaßnahme (HttpOnly, serverseitige Sitzungsführung, Verzicht auf die Spiegelung) auszuweisen. Eine Content-Security- und Referrer-Policy ist am Eingangs-Proxy derzeit nicht gesetzt.

6.8 Nutzung auf verschiedenen Endgeräten

Die fachliche Verarbeitung erfolgt serverseitig; auf den Endgeräten verbleiben Sitzungsdaten, Anzeigeeinstellungen und — konstruktionsbedingt — das kryptografische Schlüsselmaterial der Ende-zu-Ende-Verschlüsselung. Die Absicherung des Endgeräts liegt in der Verantwortung der Nutzer:innen; für Beratende gelten zusätzlich die organisatorischen Vorgaben ihres Trägers (dienstliche bzw. freigegebene Geräte).

Im Einzelnen werden auf dem Endgerät abgelegt: Zugriffs- und Erneuerungstoken sowie deren Gültigkeitszeitpunkte, die Anmeldedaten des Chat-Dienstes (Zugriffstoken, Nutzer- und Geräteerkennung), der kryptografische Speicher der Ende-zu-Ende-Verschlüsselung in einer Browser-Datenbank (IndexedDB) sowie Oberflächeneinstellungen.

Zwei Befunde sind offen auszuweisen. Erstens werden noch nicht versendete Nachrichtenentwürfe im Klartext im lokalen Speicher des Browsers abgelegt; die Ende-zu-Ende-Verschlüsselung greift erst mit dem Versand. Auf gemeinsam genutzten Geräten kann dies Beratungsinhalte offenlegen. Zweitens wird beim Abmelden zwar der lokale und der Sitzungsspeicher geleert, nicht jedoch der kryptografische Speicher in der Browser-Datenbank; Schlüsselmaterial verbleibt daher nach dem Abmelden auf dem Gerät. Beides ist als Maßnahme zu führen (Verschlüsselung bzw. Verzicht auf persistente Entwürfe; vollständiger Wipe des Krypto-Speichers beim Abmelden). Bis dahin ist der Hinweis auf die Nutzung eigener, gesperrter Geräte Teil der Nutzerinformation.

6.9 Ende-zu-Ende-Verschlüsselung und Schlüsselkonzept

Die Plattform basiert auf dem offenen Kommunikationsprotokoll Matrix mit einem selbst betriebenen Heimserver. Sämtliche Beratungsräume — Einzelberatung, anonymer Live-Chat, Gruppenchat, Supervision und interne Fallkoordination — werden serverseitig verpflichtend mit aktivierter Ende-zu-Ende-Verschlüsselung angelegt; ein unverschlüsselter Sendepfad existiert nicht.

Schlüsselkonzept.

Geräteschlüssel und Olm. Jedes Endgerät erzeugt bei der ersten Anmeldung ein eigenes Schlüsselpaar. Der direkte Austausch zwischen Geräten (insbesondere die Weitergabe von Raumschlüsseln) erfolgt paarweise verschlüsselt nach dem Olm-Verfahren.

Raumschlüssel und Megolm. Nachrichteninhalte werden mit einem Raumschlüssel nach dem Megolm-Verfahren (m.megolm.v1.aes-sha2) verschlüsselt. Der Raumschlüssel wird ausschließlich an die berechtigten Endgeräte der Raummitglieder verteilt; der Server erhält ihn zu keinem Zeitpunkt. Die Verschlüsselung ist Eigenschaft des Raums, nicht eines Schalters in der Oberfläche — ein Herabstufen einzelner Nachrichten ist konstruktionsbedingt ausgeschlossen.

Geräteprüfung (Cross-Signing). Schlüssel werden grundsätzlich nur an gegengezeichnete, also verifizierte Geräte weitergegeben. Ausgenommen sind die Endgeräte anonymer Live-Chat-Nutzer:innen, bei denen die Erreichbarkeit der Beratung Vorrang vor der Geräteisolation hat; die Verschlüsselung selbst bleibt auch dort vollständig wirksam.

Dateianhänge. Dateien werden zusätzlich clientseitig mit einem einmaligen AES-256-Schlüssel verschlüsselt, bevor sie das Endgerät verlassen. Der Server erhält weder Dateinamen noch Inhaltstyp, sondern einen nicht entschlüsselbaren Datenblock; der zugehörige Schlüssel wird ausschließlich innerhalb der Megolm-verschlüsselten Nachricht transportiert.

Serverseitiges Schlüssel-Backup („Silent Key Backup“). Zur Wiederherstellung nach Geräteverlust oder Neuansmeldung wird ein serverseitiges, seinerseits verschlüsseltes Backup aller Raumschlüssel geführt. Der Schlüssel zu diesem Backup liegt in einem verschlüsselten Geheimspeicher (Secret Storage), der ausschließlich über einen beim Nutzer verbleibenden Wiederherstellungsschlüssel geöffnet werden kann. Der Server kann die gesicherten Schlüssel nicht lesen. Ein Zurücksetzen des Backups ist destruktiv: Die zuvor gesicherte Historie wird dauerhaft unlesbar.

Geparktes Gerät (Device Dehydration). Ein zusätzliches, hinterlegtes Pseudo-Gerät zur nahtlosen Wiederaufnahme ist implementiert, steht jedoch unter einem Freigabeschalter und ist nur bei dessen Aktivierung wirksam. Es erweitert die Angriffsfläche um eine serverseitig geparkte Identität und ist bei Aktivierung gesondert zu bewerten.

Schlüsselübergabe bei Fallübergabe. Für die Weitergabe der Beratungshistorie an eine neu hinzutretende, berechnete Fachkraft werden die betreffenden Raumschlüssel gezielt und verschlüsselt an deren Gerät übertragen (Abschnitt 6.13).

Keine Föderation. Der Verbund mit fremden Matrix-Servern ist bewusst deaktiviert; es verlassen keine Beratungsdaten den Heimserver der Plattform in Richtung fremder Server.

Ehrliche Abgrenzung — was zugesichert wird und was nicht. Zugesichert wird, dass Beratungsinhalte den Server ausschließlich verschlüsselt erreichen und verlassen und dass Betreiber und Dienstleister sie nicht im Klartext einsehen können. Nicht zugesichert wird ein kryptografischer Ausschluss jeder denkbaren Betreiberhandlung: Der Heimserver verfügt über administrative Funktionen, mit denen sich Sitzungstoken für Nutzerkonten ausstellen lassen; ein so erlangter Zugang könnte künftige Schlüssel empfangen. Innerhalb einer Beratungsstelle ist die maßgebliche Vertraulichkeitsgrenze zudem nicht die Verschlüsselung, sondern die anwendungsseitige Zugriffskontrolle in Verbindung mit dem protokollierten Übergabeverfahren (ADR-002, Abschnitt 6.13). Diese Unterscheidung wird bewusst offengelegt, weil ein pauschales Verschlüsselungsversprechen den tatsächlichen Schutz falsch beschreiben würde. Als flankierende organisatorische Maßnahme ist der administrative Zugriff auf den Heimserver beim Betreiber vertraglich zu binden und zu protokollieren.

Verbesserung gegenüber der Vorgängerplattform. Auf der Vorgängerplattform war die Ende-zu-Ende-Verschlüsselung funktionsschaltergesteuert und stand neben einem serverseitigen Verschlüsselungspfad, dessen Schlüsselbestandteile vollständig auf dem Server lagen; der Betreiber konnte Inhalte dort technisch entschlüsseln. Der anonyme Live-Chat war von der Ende-zu-Ende-Verschlüsselung praktisch ausgenommen, weil das Schlüsselmaterial aus dem Anmeldepasswort abgeleitet wurde. Ferner bestand für Teilnehmende ohne eigenen öffentlichen Schlüssel ein Rückfallverfahren, dessen Ersatzschlüssel aus einer serverbekannten Kennung ableitbar war, sowie ein stiller Rückfall auf die serverseitige Verschlüsselung im Fehlerfall. In der vorliegenden Plattform bestehen weder ein serverseitiger Entschlüsselungspfad noch ein Rückfallverfahren; die Verschlüsselung gilt durchgängig für alle Chat-Formen einschließlich des anonymen Live-Chats sowie für Dateien und Sprachnachrichten.

Systembedingt verbleibende Metadaten. Auch bei wirksamer Ende-zu-Ende-Verschlüsselung verarbeitet der Heimserver Metadaten: Raumzugehörigkeit und Mitgliedschaften, pseudonyme Absenderkennung, Zeitstempel, Ereignistyp, Bezugsereignis bei Antworten und Reaktionen, Größe des Chiffrats, Lesebestätigungen sowie den Online-Status (Presence). Der Online-Status ist derzeit nicht deaktiviert; für eine Beratungsplattform ist die Abschaltung als Maßnahme zu prüfen. Reaktionen und Beziehungsangaben zwischen Ereignissen sind serverseitig sichtbar; für Reaktionsereignisse ist dies protokollbedingt.

6.10 Video- und Audio-Beratung

Die Video- und Audioberatung erfolgt browserbasiert über eine im eigenen Betrieb befindliche Medienvermittlung (LiveKit) und die darauf aufsetzende Anwendung Element Call. Die Räume für Anrufe werden nicht öffentlich beitreterbar angelegt; Zutritt erhalten nur Mitglieder des zugehörigen Beratungsraums. Die Medienströme werden zwischen den Teilnehmenden Ende-zu-Ende verschlüsselt; ist die Verschlüsselung nicht verfügbar, wird der Anruf nicht aufgebaut (Fail-closed). Eine Aufzeichnung ist nicht konfiguriert; ein Aufzeichnungs- oder Ausleitungsdienst ist nicht Bestandteil des Auslieferungsstands. Räume ohne Teilnehmende werden nach kurzer Frist automatisch verworfen. Die ausgelieferte Konfiguration der Anruferanwendung enthält keine Produkt-, Absturz- oder Fehlertelemetrie an Dritte.

Restrisiko. Beim Verbindungsaufbau werden derzeit öffentliche STUN-Server eines US-amerikanischen Anbieters angefragt. Dabei werden Client-IP-Adressen an einen Empfänger in einem Drittland übermittelt. Die Umstellung auf eigene STUN-/TURN-Komponenten ist eine erforderliche Maßnahme; bis dahin ist die Übermittlung in der Datenschutzerklärung auszuweisen.

Verbesserung gegenüber der Vorgängerplattform. Dort war die Medienverschlüsselung nur unter engen Bedingungen wirksam (bestimmte Browserfamilien, Unterstützung durch alle Teilnehmenden) und wurde beim Eintreffen weiterer Personen im Warteraum automatisch abgeschaltet; im Regelfall sah die Medienvermittlung die Inhalte.

6.11 Sprachnachrichten

Die Plattform erlaubt das Versenden kurzer Sprachnachrichten (höchstens drei Minuten) in allen Beratungs-Chat-Formen. Die Funktion ist je Träger und je Chat-Typ — Einzelberatung, anonymer Live-Chat, Gruppen, Supervision — im Administrationsbereich abschaltbar; sie ist standardmäßig aktiviert und zusätzlich an die Freigabe des Medien-Uploads gekoppelt. Eine Abschaltung auf Ebene einzelner Beratungsstellen ist derzeit nicht vorgesehen.

Besonderes Risiko. Die menschliche Stimme ist ein identifizierendes, biometrienahes Merkmal. In einem pseudonymen Beratungssetting schwächt eine Sprachnachricht die Pseudonymität der ratsuchenden Person gegenüber der beratenden Person — nicht jedoch gegenüber Plattform- oder Serverbetreiber. Ratsuchende geben ihre Stimme freiwillig und aktiv preis (bewusste Aufnahme mit Vorschau- und Verwerfen-Möglichkeit); eine heimliche Erhebung findet nicht statt.

Schutzmaßnahmen. Sprachnachrichten werden ausschließlich Ende-zu-Ende-verschlüsselt übertragen: Die Audiodatei wird clientseitig mit einem einmaligen AES-256-Schlüssel verschlüsselt, bevor sie das Endgerät verlässt; der Schlüssel wird ausschließlich innerhalb der Megolm-verschlüsselten Chat-Nachricht transportiert. Der Server speichert nur nicht entschlüsselbares Chiffprat ohne Dateinamen und ohne Inhaltstyp; auch Aufnahmedauer und -zeitpunkt liegen ausschließlich im verschlüsselten Nachrichteninhalte. Betreiber und Dienstleister können Sprachnachrichten weder anhören noch inhaltlich auswerten. Auf dem Endgerät wird kein Audio dauerhaft gespeichert. Systembedingt verbleibende Metadaten beim Serverbetreiber sind: Raumzuordnung, pseudonyme Absenderkennung, Zeitstempel und Größe des Chiffrats — aus der Größe lässt sich die Aufnahmedauer grob schätzen.

Restrisiko und geplante Maßnahmen. Die Speicherdauer verschlüsselter Mediendateien auf dem Server ist derzeit unbegrenzt; eine automatische Löschfrist (Media-Retention) sowie die Umstellung auf authentifizierte Medien-Downloads sind als technische Härungsmaßnahmen vorgesehen.

6.12 Medien-Uploads und Prüfung auf Schadsoftware

Die Plattform erlaubt Bild-Uploads in Chats — einschließlich des anonymen, registrierungsfreien Live-Chats — sowie in den redaktionellen Editoren für Rechtstexte. Für redaktionelle Bilder besteht eine serverseitige Formatvalidierung (Prüfung der Dateisignatur, zugelassen sind PNG, JPEG und WebP, kein SVG, Begrenzung auf 2 MB, authentifizierter Upload).

Für Chat-Medien existiert derzeit kein automatisierter Viren- oder Inhaltsscan. Als risikomindernde Übergangsmaßnahme werden Bilder anonymer Gäste im Live-Chat den Beratenden zunächst unkenntlich (unscharf) angezeigt und erst nach bewusster Einzelfreigabe durch die beratende Person dargestellt; ein Sperrvermerk kann von der absendenden Person nicht manipuliert werden. Diese Prüfung ist clientseitig durchgesetzt; die Datei selbst bleibt serverseitig abrufbar. Außerhalb des anonymen Live-Chats erfolgt keine Vorprüfung der Anzeige.

Die Zielarchitektur ist als Architekturentscheidung festgelegt (ADR „Media scanning via matrix-content-scanner, fail-closed“): ein vorgeschalteter Prüf-Proxy mit Virensan und optionaler KI-gestützter Bildprüfung, der ungeprüfte oder beanstandete Dateien serverseitig unzugänglich hält. Die Implementierung liegt als geprüfter, standardmäßig deaktivierter Proof of Concept vor, ist jedoch nicht produktiv ausgerollt; die Inbetriebnahme wurde im Juli 2026 priorisierungsbedingt zurückgestellt. Ein Aktivierungstermin ist nicht festgelegt. Da die Ende-zu-Ende-Verschlüsselung seit der Architekturentscheidung dauerhaft aktiv ist, setzt der Betrieb des Prüf-Proxys zusätzlich die Umsetzung des Protokolls für verschlüsselte Medien voraus. Vor Aktivierung der KI-gestützten Bildprüfung ist der Abschluss einer Auftragsverarbeitungs- bzw. Unterauftragsvereinbarung mit Zusicherung der Nichtspeicherung erforderlich; der reine Virensan ist davon unabhängig aktivierbar. Eine ebenfalls vorgesehene Bot-Abwehr am Eingang des anonymen Live-Chats ist gleichfalls nicht in Betrieb.

Restrisiko. Schadsoftware oder rechtswidrige Bildinhalte können technisch übertragen und abgerufen werden; die Exposition ist durch die Unschärfe- und Freigabemechanik sowie die Formatvalidierung nur teilweise begrenzt. Verschärfend wirkt, dass Medien-Downloads am Heimserver derzeit ohne Authentifizierung möglich sind: Wer eine Medienadresse kennt, kann den (verschlüsselten) Datenblock abrufen. Inhaltlich ist dies durch die Dateiverschlüsselung abgesichert; als Zusicherung „Zugriff nur für Berechtigte“ ist es nicht tragfähig und daher als Härungsmaßnahme geführt.

6.13 Kollegiale Fallkoordination (Team-Besprechung) und Fallübergabe

(1) Team-Besprechung. Zur Koordination einer noch nicht angenommenen Beratungsanfrage steht den Berater:innen der zuständigen Beratungsstelle ein separater, technischer Besprechungsraum zur Verfügung (ADR-016). Der Raum ist ein eigenständiger Matrix-Raum; die ratsuchende Person

ist zu keinem Zeitpunkt Mitglied dieses Raums, kann ihn nicht einsehen und nicht auffinden. Die Teilnahmeberechtigung ist deckungsgleich mit der Berechtigung, die Anfrage zu sehen: ausschließlich Berater:innen mit aktiver Zuordnung zur Beratungsstelle des Falls; ein Zugriff durch andere Beratungsstellen, den Träger oder den Plattformbetreiber über die Anwendung ist nicht vorgesehen (serverseitige Durchsetzung). Mit Annahme der Anfrage wird der Besprechungsraum automatisch und dauerhaft geschlossen; er bleibt für die Berater:innen der Beratungsstelle ausschließlich lesend erreichbar (technisch erzwungen über Matrix-Berechtigungsstufen). Anlage des Raums und Teilnahme der Berater:innen werden mit Zeitstempel protokolliert; Nachrichteninhalte werden nicht protokolliert. Ein Zustimmungs- oder Widerspruchsrecht der ratsuchenden Person besteht für die Team-Besprechung nicht; die Verarbeitung stützt sich insoweit nicht auf eine Einwilligung, sondern ist als interne fachliche Koordination ohne Offenlegung der Beratungsinhalte an zusätzliche Empfängerkreise ausgestaltet.

Ehrliche Grenzbenennung. In der Team-Besprechung wird über eine ratsuchende Person gesprochen, ohne dass diese davon Kenntnis erlangt; das Archiv bleibt dauerhaft lesbar. Damit entsteht ein Datenbestand über die betroffene Person außerhalb ihres Beratungsraums, der beim Auskunftsrecht zu berücksichtigen ist (Abschnitt 8.4). Vorgesehen ist eine Aufbewahrung von 90 Tagen ab Archivierung, spätestens jedoch bis zur Löschung der zugehörigen Beratungssitzung. Der Löschlauf ist entschieden, aber noch nicht implementiert (Stand 05.09.2026); einen Löschpfad für dieses Archiv gibt es im Auslieferungsstand nicht. Der Wert ist als Konfigurationsparameter vorgesehen und kann vom Plattformbetreiber ohne Codeänderung angepasst werden. Begründung: Der Zweck des Archivs — Kontextbrücke für eine neu übernehmende Fachkraft — ist mit der Fallannahme im Kern erfüllt; danach verbleibt reiner Prozessdaten-Fließtext über die ratsuchende Person, dessen unbefristete Aufbewahrung sich gegenüber der Speicherbegrenzung (§ 7 Abs. 1 lit. e KDG) nicht rechtfertigen lässt (Caritas-Fachposition: Prozessdaten werden nach Beendigung des Klientenverhältnisses gelöscht). Der Wert ist eine Konvention, kein Normwert, und steht unter dem Vorbehalt der Freigabe durch den betrieblichen Datenschutzbeauftragten. Protokolliert werden derzeit ausschließlich Anlage und Teilnahme, nicht Lese- oder Archivzugriffe.

(2) Fallübergabe. Der Zugriff einer weiteren Beraterin oder eines weiteren Beraters auf einen bestehenden Beratungsfall — etwa bei Vertretung im Krankheitsfall, Urlaubsvertretung, kollegialer Beratung oder Ausscheiden — erfolgt ausschließlich über ein strukturiertes Übergabeverfahren. Antragsberechtigt sind nur Berater:innen derselben Beratungsstelle. Jeder Antrag erfordert die Angabe eines katalogisierten Grundes sowie einer Begründung. Je Grund ist festgelegt, ob die vorherige Zustimmung der ratsuchenden Person erforderlich ist. Ist die Zustimmung erforderlich, verbleibt der Antrag im Status „ausstehend“; die ratsuchende Person entscheidet selbst in der Anwendung über Annahme oder Ablehnung; erst danach wird der Zugriff gewährt oder verweigert. Ist keine Zustimmung erforderlich — Standardfall bei Krankheit, Urlaub, Notfall und Ausscheiden —, wird die ratsuchende Person unmittelbar nach der Übernahme durch eine Systemnachricht im Beratungsverlauf über die Übernahme und deren Grund informiert. Die bisherige Fachkraft bleibt Mitglied des Raums, sodass eine Rückübernahme möglich ist.

(3) Protokollierung. Jeder Übergabeantrag — einschließlich verweigerter Anträge — wird revisionsfähig gespeichert (antragstellende und bisherige Fachkraft, Grund, Ergebnis, Zustimmungserfordernis, maßgebliche Richtlinie, Zeitstempel). Beratungsinhalte sind nicht Bestandteil der Protokolldaten. Die Einsichtnahme in die Protokolle ist rollenbasiert beschränkt und mandanten- sowie beratungsstellenscharf gefiltert; Administratorkonten ohne Beratungsstellen-Zuordnung erhalten keinen Protokollzugriff (Fail-closed-Prinzip).

Restrisiko. Das Pflicht-Freitextfeld „Begründung“ wird gespeichert und der Administration angezeigt; es kann im Einzelfall fallbezogene Inhalte enthalten. Solange keine Maskierung erfolgt, ist die Aussage „ohne Inhalte“ nur mit dieser Einschränkung zutreffend. Als Maßnahmen sind ein Hinweis in der Eingabemaske („keine Fallinhalte in die Begründung“) sowie die Maskierung des Feldes in den Administrationsprotokollen vorgesehen. Ein Grund aus dem Katalog („Fachkraft erkrankt“) ist zugleich ein Gesundheitsdatum der beratenden Person und daher beschäftigendatenschutzrechtlich zu würdigen.

(4) Technische Vertraulichkeit. Beide Raumtypen werden serverseitig als private, nicht auffindbare Matrix-Räume mit aktivierter Ende-zu-Ende-Verschlüsselung angelegt. Die maßgebliche

Vertraulichkeitsgrenze gegenüber nicht fallführenden Berater:innen derselben Beratungsstelle ist jedoch nicht die Verschlüsselung, sondern die anwendungsseitige Zugriffskontrolle (Sichtbarkeits- und Berechtigungssteuerung, beratungsstellenscharfe Suche) in Verbindung mit dem protokollierten Übergabeverfahren; gegenüber Dritten außerhalb der Beratungsstelle besteht zusätzlich eine Trennung auf Ebene der Raum-Mitgliedschaft.

(5) Konfigurierbarkeit. Die Team-Besprechung ist je Mandant (Träger) durch die Plattformadministration aktivierbar bzw. deaktivierbar; zusätzlich besteht ein deployment-weiter Schalter. Der Grundkatalog der Fallübergabe einschließlich des Zustimmungserfordernisses je Grund ist administrativ konfigurierbar, derzeit jedoch plattformweit und nicht je Träger. Eine durchgängige Delegationskaskade bis auf die Ebene einzelner Beratungsstellen besteht für diese beiden Funktionen nicht; sie darf für sie nicht behauptet werden.

(6) Supervision — Abgrenzung. Die Supervision ist ein hiervon getrenntes drittes Werkzeug: Sie ist als begleitender Lesezugriff ausgestaltet. Die stehende Supervision ist dauerhaft aktiv und für die ratsuchende Person nicht abschaltbar (Entscheidung vom 05.09.2026, ADR-008-Addendum): Sie ist Teil der fachlichen Arbeitsweise der Beratungsstelle; die supervidierende Person gehört derselben Beratungsstelle an, liest ausschließlich mit, schreibt nicht in den Beratungsraum und ist für die ratsuchende Person nicht sichtbar. An die Stelle eines Widerspruchsverfahrens tritt die aktive Aufklärung: Die ratsuchende Person wird in den Datenschutzhinweisen der Beratungsstelle beim Einstieg in den Chat informiert und soll zusätzlich eine Systemnachricht im eigenen Beratungsraum erhalten, sobald eine Berater:in die Anfrage angenommen hat — also in dem Moment, in dem die stehende Supervision angehängt wird. Diese Systemnachricht ist entschieden, aber noch nicht implementiert (Stand 05.09.2026; ORISO-Frontend#1315). Ein technisch weiterhin vorhandener Opt-out-Endpunkt wird in der Anwendung nicht angeboten; sein Rückbau ist offen. Die Fallübergabe behält ihr eigenes Widerspruchsverfahren, davon unberührt. Zu Supervisionsvorgängen können Freitext-Notizen erfasst werden; sie können besondere Kategorien personenbezogener Daten über die ratsuchende Person enthalten (§ 11 KDG, Art. 9 DSGVO). Vorgesehen ist eine Aufbewahrung von Fallende + 90 Tagen (Startzeitpunkt: Abschluss bzw. Archivierung der Beratungssitzung, hilfsweise Aufhebung der Supervisionsbeziehung — was zuerst eintritt). Der Löschlauf ist entschieden, aber noch nicht implementiert (Stand 05.09.2026); heute wird beim Löschen von Sitzung oder Beratendem nur die Datenbankzeile entfernt, der Matrix-Nebenraum bleibt unbefristet bestehen. Der Wert ist als Konfigurationsparameter vorgesehen und kann vom Plattformbetreiber ohne Codeänderung angepasst werden. Begründung: Mit dem Fallende entfällt der Zweck der Fachaufsicht; es verbleibt reiner Prozessdaten-Fließtext über die ratsuchende Person, der nach der Caritas-Fachposition „nach Beendigung des Klientenverhältnisses gelöscht“ werden soll. Der Wert ist eine Konvention, kein Normwert, und steht unter dem Vorbehalt der Freigabe durch den betrieblichen Datenschutzbeauftragten.

(7) Grundkatalog und besondere Kategorien — Ist-Stand und Beschlusslage. Der ausgelieferte Grundkatalog enthält die Gründe COUNSELLOR_ASKED_FOR_ADVICE, COUNSELLOR_ON_HOLIDAY, OTHER_EMERGENCY, COUNSELLOR_IS_ILL und COUNSELLOR_LEFT. Der Grund „Fachkraft erkrankt“ (COUNSELLOR_IS_ILL) ist ein Gesundheitsdatum über die beratende Person § 11 KDG / Art. 9 DSGVO; er wird in den Übergabedatensatz, in das Verwaltungsprotokoll, in die Benachrichtigungsparameter und — als abgeleiteter Anzeigetext — in den Beratungsraum der ratsuchenden Person geschrieben. Am 05.09.2026 ist entschieden worden, den Katalog auf die anlassneutralen Gründe PLANNED_ABSENCE, UNPLANNED_ABSENCE, ASSIGNMENT_ENDED und ADVICE_REQUESTED umzustellen und den Text an die ratsuchende Person weder Ursache noch Dauer nennen zu lassen (Addendum zu ADR-002-silent-room-membership-and-access-control-curtain.md). Ebenfalls entschieden, aber noch nicht ausgeliefert, ist die zweite Übergaberichtung („Fall abgeben“: Angebot, Annahme durch die Empfängerin, danach derselbe Freigabepfad; die Annahme ist ausdrücklich keine dritte Einwilligungsschwelle im Sinne von ADR-022). Beides ist im Auslieferungsstand nicht vorhanden und darf bis zur Umsetzung nicht als Ist-Zustand beschrieben werden; bereits gesendete Raum-Ereignisse sind unveränderlich und können nicht nachträglich anlassneutral gemacht werden.

(8) Belegkette. Funktionsbeschreibung: Case Handover. Architekturentscheidungen (nach Dateinamen zitiert, nicht nach Nummer):

ADR-002-silent-room-membership-and-access-control-curtain.md — stille Raum-Mitgliedschaft, Vorhang aus Zugriffskontrolle, Addendum vom 05.09.2026;

ADR-016-team-besprechung-side-room-hard-close-at-accept.md — harter Abschluss des Besprechungsraums; ADR-022-consent-gates-and-re-consent-in-counselling-sessions.md — genau zwei Einwilligungsschwellen. Code: Endpunkte, Zustimmungserfordernis je Grund, mandanten- und beratungsstellenscharfe Protokollsicht, ausgelieferter Grundkatalog. Die maschinenlesbare Fassung dieser Belege steht unter den Kennungen case-handover-* in evidence-map.yaml.

Offener Punkt. Für die Übergabeprotokolle besteht keine Aufbewahrungsfrist: Die Konfiguration des Dienstes kennt Fristen für Benachrichtigungen (90 Tage nach Kenntnisnahme, 365 Tage absolut) und für die Protokolle des Break-Glass-Zugriffs (12 Monate), nicht aber für case_handover_request. Gelöscht wird dort nur anlassbezogen mit dem Konto der beratenden Person. Vorgesehen ist eine Aufbewahrung von 12 Monaten ab Entstehung des Protokolleintrags, mit täglichem Löschlauf. Der Löschlauf ist entschieden, aber noch nicht implementiert (Stand 05.09.2026). Der Wert ist als Konfigurationsparameter vorgesehen und kann vom Plattformbetreiber ohne Codeänderung angepasst werden. Begründung: Das Log enthält keine Gesprächsinhalte und dient allein der Nachprüfbarkeit, wer wann mit welchem Grund Zugriff auf einen Fall erhalten hat; die verbindliche Untergrenze von sechs Monaten (§ 6 lit. f Satz 2 KDG-DVO, Eingabekontrolle) wird nicht unterschritten, und der Wert folgt dem bereits ausgelieferten Break-Glass-Audit (zwölf Monate). Die Frist ist im Löschkonzept (Anlage 2) endgültig festzulegen; sie ist eine Entscheidung des Verantwortlichen, keine technische Ableitung, und steht unter dem Vorbehalt der Freigabe durch den betrieblichen Datenschutzbeauftragten.

6.14 In-App-Benachrichtigungen und E-Mail-Benachrichtigungen

In-App-Benachrichtigungen („Zeitstrahl“). Je Benachrichtigungsereignis wird serverseitig ein Datensatz gespeichert (mandantengetrennt): Empfänger-Pseudonym, Ereignistyp, Erstell- und Lesezeitpunkt, Sitzungsreferenz, ein anwendungsinterner Verweis sowie Anzeigetexte und strukturierte Metadaten.

Inhalte der Beratungskommunikation werden nicht gespeichert: Nachrichtentexte aus der Ende-zu-Ende-verschlüsselten Chat-Kommunikation erreichen die Benachrichtigungsverarbeitung konstruktionsbedingt nicht, da verschlüsselte Ereignisse keinen Nachrichtenkörper tragen; der konfigurierbare Vorschaumodus ist in allen Umgebungen fest auf „keine Vorschau“ gesetzt, sodass auch clientseitig übermittelte Vorschautexte verworfen werden.

Gespeichert werden jedoch Kommunikationsmetadaten: wer wem wann in welcher Sitzung geschrieben hat, der Inhaltstyp der Nachricht, Anzeigenamen von Beratenden und bei neuen Anfragen die Themenkategorie der Beratung, die für sich genommen bereits einen Rückschluss auf den Beratungsanlass zulässt. Bei Fallübergaben fließt derzeit zusätzlich der von Beratenden verfasste Begründungs-Freitext in die Anzeigetexte ein und kann im Einzelfall Rückschlüsse auf Beratungsinhalte zulassen. Der Lesezeitpunkt wird sekundengenau je Benachrichtigung gespeichert und ermöglicht ein Nutzungs- und Anwesenheitsprofil.

Der Zugriff ist strikt auf den jeweiligen Empfänger beschränkt; ein administrativer Lesezugriff über die Schnittstelle besteht nicht. Betroffene können ihren Benachrichtigungsverlauf jederzeit selbst vollständig löschen. Seit dem Auslieferungsstand vom 14.08.2026 bestehen zwei Regelfristen: gelesene Benachrichtigungen werden 90 Tage nach der Kenntnisnahme gelöscht, alle übrigen spätestens 365 Tage nach ihrer Entstehung; ein nächtlicher Löschlauf (03:15 Uhr) setzt beide durch, beide Werte sind je Umgebung konfigurierbar (EVENT_NOTIFICATION_RETENTION_READ_DAYS, EVENT_NOTIFICATION_RETENTION_ABSOLUTE_DAYS; der Wert 0 schaltet die jeweilige Frist ab). Der Konto-Löschworkflow entfernt die Datensätze seither mit; er führt für Ratsuchende und für Beratende je einen eigenen Löschschritt aus.

Vorbehalt. Die beiden Fristen sind der Vorschlag dieser DSFA und noch nicht durch die Datenschutzbeauftragung des Verantwortlichen bestätigt; sie stehen so auch als Kommentar in der Konfiguration des Dienstes.

Geplante Abhilfemaßnahmen: (1) Abschluss der laufenden Umstellung auf rein clientseitig gerenderte Benachrichtigungstexte, wodurch die serverseitigen Klartext-Anzeigetexte einschließlich des Fallübergabe-Freitexts vollständig entfallen; (2) Reduktion des Lesezeitstempels auf ein Gelesen-Kennzeichen; (3) Entfernung des Vorschaumodus aus dem Quellcode, damit eine bloße Konfigurationsänderung die Tabelle nicht in einen Inhaltsspeicher verwandeln kann.

E-Mail-Benachrichtigungen. Benachrichtigungen per E-Mail verlassen die Domäne der Ende-zu-Ende-Verschlüsselung. Versendet werden Einladungen, Passwort-Zurücksetzungen, Einmalcodes für die Zwei-Faktor-Authentisierung, Hinweise auf neue Anfragen sowie Meldungen zur Vertragsunterzeichnung. Chat- oder Beratungsinhalte sind nicht Bestandteil dieser Nachrichten; verifiziert ist, dass keine Nachrichtentexte versendet werden. Enthalten sind jedoch je nach Anlass die Postleitzahl der Anfrage, der Name der Beratungsstelle, der Name der beratenden Person sowie in einzelnen Fällen das Pseudonym der ratsuchenden Person. Bereits die Zustellung offenbart gegenüber der Mail-Infrastruktur das Bestehen einer Beratungsbeziehung. Der Versand erfolgt über mehrere Wege (Anwendungsdienste, Mandanten-Mailserver, Beratungstypdienst) mit verpflichtender Transportverschlüsselung (STARTTLS).

Restrisiko. Zugangsdaten der Mailserver werden nicht einheitlich geschützt: An einer Stelle liegen sie verschlüsselt vor, an einer weiteren nur dann, wenn ein Geheimnis gesetzt ist, und an einer dritten unverschlüsselt in einem Konfigurationsdatensatz. Die Vereinheitlichung (Verschlüsselung ruhender Daten, ausschließlicher Schreibzugriff über die Schnittstelle) ist eine erforderliche Maßnahme (siehe auch Abschnitt 6.16). Push-Benachrichtigungen an mobile Geräte über einen US-amerikanischen Dienst sind im Auslieferungsstand deaktiviert; sie enthalten konstruktionsbedingt keine Inhalte, würden aber Metadaten in ein Drittland übermitteln und wären vor Aktivierung gesondert zu bewerten.

6.15 Statistische Auswertung

Statistische Auswertungen erfolgen ausschließlich aggregiert und losgelöst von einzelnen Beratungsfällen. Im Administrationsbereich steht ein Statistik-Dashboard zur Verfügung, das Aggregatzahlen anzeigt (neue Beratungsanfragen, aktive Fälle, Themenverteilung, Anzahl Beratender, Gruppenchats — je Träger bzw. Beratungsstelle, tages-, wochen- und monatsweise); Einzelpersonen sind daraus nicht ablesbar. Zum Schutz vor Rückschlüssen aus kleinen Gruppen greift eine Kleinstzellen-Unterdrückung: Aggregate werden erst ab mindestens fünf beitragenden Beratenden ausgewiesen, andernfalls wird der Wert unterdrückt; die Prüfung ist fail-closed ausgelegt und in der Produktivumgebung erzwungen.

Für die Nachrichtenstatistik der Beratenden wird keine Klarkennung gespeichert: Die Zählung erfolgt unter einem kryptografischen Pseudonym (HMAC-SHA256 über die Beraterkennung mit serverseitig verwaltetem Geheimnis). Beratende können ausschließlich ihre eigenen Kennzahlen einsehen; eine personenbezogene Leistungsauswertung durch Dritte findet über die Anwendung nicht statt.

Ehrliche Grenzbenennung. Die Pseudonymisierung ist nicht vollständig wirksam: Neben dem Pseudonym wird die Kennung der auslösenden Beratungssitzung im Klartext geführt, sodass eine Re-Identifikation über eine Verknüpfung mit den Sitzungsdaten möglich bleibt. Eine Aufbewahrungsfrist besteht für diese Zähldaten nicht, und sie werden beim Löschen eines Beraterkontos nicht entfernt. Ferner besteht ein Einzelfall-Endpunkt für Sitzungsdaten einschließlich Postleitzahl, der technischen Dienstkonto vorbehalten ist. Schließlich kann die Anwendung Statistikereignisse an einen Nachrichtenbus veröffentlichen; das Registrierungsereignis enthielte Kontokennung, Alter, Geschlecht, Postleitzahl, Thema und Herkunftsverweis in einem Datensatz. Diese Veröffentlichung ist im Auslieferungsstand abgeschaltet, ein verarbeitender Empfänger ist in den geprüften Beständen nicht auffindbar, und eine Transportverschlüsselung des Nachrichtenbusses ist nicht konfiguriert. Vor Aktivierung sind

Empfänger, Speicherort, Aufbewahrung und Löschpropagation zu klären und der Ereignisinhalt zu minimieren.

6.16 Mandantentrennung

Die Plattform ist mandantenfähig: Jeder Träger bildet einen Mandanten, dem Beratungsstellen, Beratende, Rechtstexte und Konfiguration zugeordnet sind. Die Trennung wird über eine Mandantenkennung an den Datensätzen und einen anwendungsseitigen Filter durchgesetzt; sie ist damit applikationsseitig, nicht datenbankseitig realisiert. Fachliche Datenbestände wie die Fallübergabe-Protokolle und die Benachrichtigungen tragen die Mandantenkennung und werden entsprechend gefiltert; administrative Auswertungen sind auf die Agenturen der aufrufenden Person beschränkt und verhalten sich fail-closed.

Risiko und Kompensation. Eine rein anwendungsseitige Trennung ist gegenüber Fehlkonfiguration und Programmierfehlern empfindlich; ein trägerübergreifender Sichtbarkeitsfehler ist in der Vergangenheit aufgetreten und behoben worden. Kompensierend wirken die konsequente Filterung an den Zugriffsschichten, das fail-closed-Verhalten administrativer Auswertungen sowie eine eingeschränkte Agentur-Administrationsrolle. Als Maßnahmen sind Regressionstests für die Mandantentrennung sowie eine Prüfung datenbankseitiger Trennung auszuweisen.

Offen auszuweisender Befund. Die Plattform-Administration kann die vollständigen Einstellungen jedes Mandanten abrufen. Darin enthalten sind derzeit auch Mailserver-Zugangsdaten des Trägers im Klartext, die zudem unverschlüsselt gespeichert werden; ebenso sind die Signaturdaten der Auftragsverarbeitungsvereinbarungen trägerübergreifend einsehbar. Erforderlich sind: ausschließlich schreibender Zugriff auf Geheimnisse über die Schnittstelle, deren Verschlüsselung im Ruhezustand sowie eine Trennung zwischen Betriebs- und Einsichtsrechten (Break-Glass-Zugriff mit Freigabe des Trägers, zeitlicher Befristung und Protokollierung). Bis zur Umsetzung ist der Kreis der Plattform-Administrator:innen eng zu halten, vertraglich zu binden und zu dokumentieren.

6.17 Betrieb, Observability und Telemetrie

Protokollierung der Dienste. Die Anwendungsdienste schreiben strukturierte Protokolle auf die Standardausgabe; eine Rotation oder Aufbewahrung findet in den Diensten selbst nicht statt, sie obliegt der Container-Plattform. Der Protokollkontext enthält keine Kontokennung, sondern eine Korrelationskennung. Gleichwohl gelangen an einzelnen Stellen personenbezogene Angaben in Protokolltexte: Kontokennungen, Benutzernamen im Klartext, in Einzelfällen vollständige E-Mail-Adressen sowie — auf Fehlersuchstufe — Inhalte von Zugriffstoken. Die Protokollstufe ist zur Laufzeit über einen freigegebenen Verwaltungsendpunkt veränderbar. Maßnahmen: Absicherung des Verwaltungsendpunkts, Entfernen der Datensatz-Ausgaben mit Namen und E-Mail-Adressen, Bereinigungsfilter für personenbezogene Angaben sowie eine ausdrückliche Aufbewahrungsfrist für den Protokollbestand.

Ablaufverfolgung und Metriken. Eine Anbindung an eine Beobachtungsplattform (SigNoz) ist vorbereitet; der Export ist im Auslieferungsstand standardmäßig und in der Produktivumgebung deaktiviert. In der Vorabumgebung werden ausschließlich Metriken exportiert, keine Ablaufverfolgungen. Vor einer Aktivierung ist zu prüfen, ob Ablaufverfolgungen Pfade mit Kennungen tragen; Aufbewahrung und Zugriffsschutz der Beobachtungsplattform sind festzulegen.

Fehlermeldungen aus dem Browser. Die Anwendung kann Fehlermeldungen aus dem Browser an den Server melden (Meldungstext, aufgerufene Adresse, Browserkennung, Aufrufkette, Korrelationskennung, jeweils längenbegrenzt). Diese Angaben können Personenbezug tragen und unterliegen der Protokoll-Aufbewahrung. Eine Übermittlung an externe Telemetriedienste findet aus dem Browser nicht statt.

Sicherung und Wiederherstellung. Für die Datenbank des Chat-Dienstes bestehen Sicherungs- und Wiederherstellungsverfahren mit einer Aufbewahrung von 30 Tagen für Vollsicherungen und sieben

Tagen für die fortlaufende Protokollsicherung. Für die übrigen Kern-Datenbanken sind im Auslieferungsstand keine Sicherungsaufträge hinterlegt — eine Verfügbarkeitslücke im Sinne der Sicherheit der Verarbeitung nach § 26 KDG / Art. 32 DSGVO. Vor allem aber enthalten die Sicherungsskripte einen Pfad, der Datenbankauszüge in ein externes Quellcode-Verwaltungssystem eines US-amerikanischen Anbieters überträgt. Ob dieser Pfad aktiviert ist, ist vor Freigabe dieser DSFA verbindlich zu klären; bei Aktivierung liegt eine unzulässige Drittlandübermittlung mit praktisch unlöschbarer Historie vor. Ferner ist zu beachten, dass gelöschte Daten bis zum Ablauf der Sicherungsfrist in den Sicherungen fortbestehen.

Übersetzung von Rechtstexten. Für die Übersetzung der mandantenspezifischen Rechtstexte (Impressum, Datenschutzerklärung, Auftragsverarbeitungsvereinbarung) kann eine externe Sprachmodell-Schnittstelle genutzt werden. Übermittelt wird der vollständige Text einschließlich der darin enthaltenen Namen, Anschriften und E-Mail-Adressen der Verantwortlichen und Datenschutzbeauftragten. Die Anbieter haben ihren Sitz außerhalb des Geltungsbereichs; die Nutzung setzt eine Auftragsverarbeitungsvereinbarung sowie eine Prüfung der Drittlandübermittlung voraus. Beratungsinhalte werden zu keinem Zeitpunkt an Sprachmodell-Dienste übermittelt.

Betriebsseitige Härtungspunkte am Chat-Dienst. Im Auslieferungsstand sind die offene Registrierung ohne Verifikation aktiviert, die Ratenbegrenzungen praktisch aufgehoben, Medien ohne Authentifizierung abrufbar und weder für Nachrichten noch für Medien eine Aufbewahrungsfrist gesetzt. Diese Punkte widersprechen dem Grundsatz, dass Konten ausschließlich über die Anwendung entstehen, und sind vor Produktivbetrieb zu schließen.

6.18 Löschung und Aufbewahrung

Die Löschfristen je Datenkategorie sind im Löschkonzept (Anlage 2) zusammengeführt. Technisch bestehen folgende Verfahren:

Kontolöschung durch die betroffene Person. Ratsuchende können ihr Konto selbst löschen. Die Löschung durchläuft ein Schutzfenster von 48 Stunden mit ausschließlich lesendem Zugriff und wird anschließend automatisiert vollzogen. Der Löschlauf entfernt in fester Reihenfolge das Identitätskonto, das Chat-Konto (mit ausdrücklichem Löschkennzeichen und Bereinigung der Räume), Sitzungen und deren Zusatzdaten, Themenzuordnungen, Supervisionszuordnungen, Fallübergabe-Anträge, Agenturzuordnungen, den Eintrag in der Pseudonym-Registrierung, mobile Gerätekennungen und schließlich den Kontodatensatz. Eine Aussetzung der Löschung ist für drei bis höchstens zwölf Monate möglich und wird mit Grund dokumentiert.

Anonyme Konten. Deaktivierung nach 360 Minuten Inaktivität, Löschung nach 2 820 Minuten (47 Stunden), jeweils stündlich geprüft.

Gruppenchats. Abgelaufene Gruppenchats werden minütlich geprüft und deaktiviert.

Nur registrierte Konten ohne Beratung. Ein Löschlauf nach 30 Tagen ist implementiert, im Auslieferungsstand jedoch deaktiviert; bleibt er aus, verbleiben Konten mit hinterlegter E-Mail-Adresse unbegrenzt.

Nachweisdaten. Signaturen zu Auftragsverarbeitungsvereinbarungen werden im Zustand „abgelehnt“ nach einer konfigurierten Frist gelöscht, im Zustand „unterzeichnet“ zu Nachweiszwecken aufbewahrt. Das Prüfprotokoll der Support-Zugriffe wird nach zwölf Monaten automatisiert gelöscht — die einzige im Bestand ausdrücklich dokumentierte Aufbewahrungsfrist.

Grabstein-Datensatz. Nach der endgültigen Löschung verbleibt ein Verweisdatensatz, der die vollständige frühere Kontokennung sowie ein neutrales Anzeigekennzeichen enthält, damit Verweise in fortbestehenden Datensätzen aufgelöst werden können. Er ist unbefristet angelegt.

Ehrliche Lückenbenennung — was der Löschlauf derzeit nicht erfasst. Vom Konto-Löschlauf nicht berührt werden: die In-App-Benachrichtigungen, die serverseitig gespeicherten Nachrichtenentwürfe, die pseudonymisierte Nachrichtenstatistik der Beratenden, das Archiv der versendeten Einladungs-E-Mails, das Prüfprotokoll der Inaktivitätsbenachrichtigungen sowie eine

aus der Migration verbliebene Zuordnungstabelle zwischen Person und Chat-Raum, die im Datenmodell der Anwendung nicht abgebildet ist und deshalb für alle Löschverfahren unsichtbar bleibt. Für keine dieser Kategorien besteht zudem eine zeitliche Aufbewahrungsgrenze. Hinzu kommt, dass am Chat-Dienst weder für Nachrichten noch für Mediendateien eine Aufbewahrungsfrist gesetzt ist und dass gelöschte Daten bis zum Ablauf der Sicherungsfristen in Sicherungen fortbestehen. Die Aussage einer „vollständigen“ Löschung darf erst geführt werden, wenn diese Lücken geschlossen sind; bis dahin sind sie als Maßnahmen im Löschkonzept aufzunehmen. Diese Offenlegung ist bewusst gewählt: Eine DSFA, die eine unvollständige Löschung als vollständig beschreibt, verlöre ihren Zweck.

6.19 Übersicht der Datenkategorien und Empfänger

Löschfristen je Datenkategorie: siehe Anlage 2 — Löschkonzept (in Vorbereitung). Empfänger und Auftragsverarbeiter: siehe Kapitel 4.

Querformat-Tabelle — horizontal scrollbar im eigenen Container

| Betroffene | Quelle | Datenkategorien | Schutzklasse

| Ratsuchende mit Registrierung | Eigenangabe bei Registrierung und Nutzung | - systemgenerierter, pseudonymer Benutzername; Passwort-Hash - Postleitzahl (unverifiziert); je nach Fachbereich optionale Angaben (z. B. Alter, Anliegen) - optional E-Mail-Adresse, 2FA-Merkmale - Ende-zu-Ende-verschlüsselte Beratungsinhalte, Dateien und Sprachnachrichten - Sitzungs- und Benachrichtigungs-Metadaten | I–III je nach freiwilligen Angaben

| Ratsuchende Live-Chat, ohne Registrierung | Systemgeneriert | - generierter, pseudonymer Benutzername - temporäre Sitzungsdaten; automatisierte Löschung nach kurzer Frist | I–III

| Beratende | Einladung durch Administrator:innen der Träger | - Name, dienstliche E-Mail-Adresse - Beratungsstelle, Rolle/Teamzuordnung, 2FA-Status - pseudonymisierte Tätigkeitsstatistik (HMAC) | I

| Träger-Vertreter:innen AVV-Unterzeichnung, keine App-Nutzer | Eigenangabe im Signaturprozess | - Name, Funktion, Organisation, E-Mail-Adresse - Signaturstatus und -zeitpunkt (Nachweiszweck, § 29 KDG / Art. 28 DSGVO) | I

| Administrator:innen | Anlage durch Betreiber bzw. Träger | - Name, E-Mail-Adresse, Rolle, Mandanten-/Beratungsstellen-Zuordnung | I

Kapitel 7

Rechtsgrundlagen

Technischer Teil — von ORISO gepflegt —

Die Verarbeitung stützt sich je Verarbeitungsschritt auf unterschiedliche Erlaubnistatbestände. Die nachstehende Zuordnung nennt jeweils die Norm des Gesetzes über den Kirchlichen Datenschutz (nachfolgend „KDG“) und in Klammern das Pendant der Datenschutz-Grundverordnung (nachfolgend „DSGVO“), sodass sie über das Compliance-Preset umgeschaltet werden kann.

7.1 Übersicht

| # | Verarbeitungsschritt | Rechtsgrundlage KDG | Pendant DSGVO

| 1 | Technische Nutzungs- und Betriebsdaten (Sitzungssteuerung, technisch notwendige Cookies, Zugriffs- und Fehlerprotokolle, Betriebssicherheit) | § 6 Abs. 1 lit. g KDG | (Art. 6 Abs. 1 lit. f DSGVO)

- | 2 | Registrierungsdaten der Ratsuchenden (systemgeneriertes Pseudonym, Passwort-Hash, Postleitzahl) | § 6 Abs. 1 lit. b KDG | (Art. 6 Abs. 1 lit. a DSGVO)
- | 3 | Freiwillige Zusatzangaben (E-Mail-Adresse, Alter, Geschlecht, Beratungsanlass, Zwei-Faktor-Merkmale) | § 6 Abs. 1 lit. b KDG | (Art. 6 Abs. 1 lit. a DSGVO)
- | 4 | Beratungsinhalte einschließlich besonderer Kategorien personenbezogener Daten | § 6 Abs. 1 lit. b i. V. m. § 11 Abs. 1 lit. a KDG | (Art. 9 Abs. 2 lit. a DSGVO)
- | 5 | Anonyme Live-Chat-Nutzung ohne jede personenbezogene Angabe | Anwendungsbereich des KDG nicht eröffnet | (Anwendungsbereich der DSGVO nicht eröffnet)
- | 6 | Daten der Beratenden und der Administration (Konto, Rollen, Zuordnung, Zwei-Faktor-Status) | § 6 Abs. 1 lit. g und lit. f KDG | (Art. 6 Abs. 1 lit. b oder lit. f DSGVO)
- | 7 | Pseudonymisierte Tätigkeitsstatistik der Beratenden | § 6 Abs. 1 lit. g KDG | (Art. 6 Abs. 1 lit. f DSGVO)
- | 8 | Interne Fallkoordination und Fallübergabe (Team-Besprechung, Übergabeprotokoll, Supervision) | § 6 Abs. 1 lit. g KDG, bei zustimmungspflichtigen Übergabegründen zusätzlich § 6 Abs. 1 lit. b KDG | (Art. 6 Abs. 1 lit. f bzw. lit. a DSGVO)
- | 9 | Signaturdaten der Träger-Vertreter:innen zur Auftragsverarbeitungsvereinbarung | § 6 Abs. 1 lit. c i. V. m. § 29 KDG | (Art. 6 Abs. 1 lit. c i. V. m. Art. 28 DSGVO)
- | 10 | Protokoll- und Nachweisdaten (Zugriffs-, Einladungs- und Support-Protokolle) | § 6 Abs. 1 lit. c und lit. g KDG | (Art. 6 Abs. 1 lit. c und lit. f DSGVO)

7.2 Daten der Ratsuchenden

- (1) Technische Nutzungsdaten. Für den Betrieb der Plattform sind Sitzungssteuerung, Authentifizierung, technisch notwendige Cookies sowie Betriebs- und Sicherheitsprotokolle erforderlich. Diese Verarbeitung erfolgt auf Grundlage des berechtigten Interesses nach § 6 Abs. 1 lit. g KDG / Art. 6 Abs. 1 lit. f DSGVO. Das Interesse liegt in der Bereitstellung eines funktionsfähigen, verfügbaren und gegen Missbrauch geschützten Beratungsangebots. Überwiegende schutzwürdige Interessen der Betroffenen stehen nicht entgegen, weil die Verarbeitung auf das technisch Erforderliche begrenzt ist, keine Tracking- oder Analysedienste eingesetzt werden und die Anwendungsdienste keine IP-Adressen in ihren Fachdatenbeständen führen. Einschränkung ist zu berücksichtigen, dass IP-Adressen in Zugriffsprotokollen des Eingangs-Proxys und des Identitätsmanagements anfallen (Abschnitt 6.6); für diese ist eine Aufbewahrungsfrist festzulegen, um die Erforderlichkeit zu wahren.
- (2) Registrierungsdaten. Die Registrierung ist freiwillig; Ratsuchende entscheiden selbst über die Inanspruchnahme des Angebots. Die Verarbeitung des systemgenerierten Pseudonyms, des Passwort-Hashwerts und der Postleitzahl beruht auf der Einwilligung nach § 6 Abs. 1 lit. b KDG / Art. 6 Abs. 1 lit. a DSGVO, die im Registrierungsvorgang eingeholt und dokumentiert wird. Die Postleitzahl ist die einzige Pflichtangabe und dient ausschließlich der Zuordnung zur zuständigen Beratungsstelle; ihre Richtigkeit wird nicht geprüft.
- (3) Freiwillige Zusatzangaben. Die Hinterlegung einer E-Mail-Adresse, die Aktivierung der Zwei-Faktor-Authentisierung und fachbereichsbezogene Angaben (unter anderem Alter, Geschlecht, Beziehungskonstellation, Beratungsanlass) sind freiwillig und beruhen ebenfalls auf der Einwilligung nach § 6 Abs. 1 lit. b KDG / Art. 6 Abs. 1 lit. a DSGVO. Sie können jederzeit widerrufen werden; die Folgen des Widerrufs sind in Abschnitt 8.10 dargestellt.
- (4) Beratungsinhalte. Beratungsinhalte enthalten regelmäßig besondere Kategorien personenbezogener Daten im Sinne des § 11 KDG / Art. 9 DSGVO. Die Verarbeitung beruht auf der ausdrücklichen Einwilligung nach § 6 Abs. 1 lit. b i. V. m. § 11 Abs. 1 lit. a KDG / Art. 9 Abs. 2 lit. a DSGVO, die vor Beginn der Beratung eingeholt wird. Ergänzend ist zu berücksichtigen, dass der Plattformbetreiber die Inhalte technisch nicht zur Kenntnis nehmen kann, weil sie ausschließlich Ende-zu-Ende-verschlüsselt übertragen und gespeichert werden (Abschnitt 6.9); die

Ende-zu-Ende-Verschlüsselung ist insoweit nicht Rechtsgrundlage, wohl aber eine wesentliche technische Schutzmaßnahme im Sinne des § 26 KDG / Art. 32 DSGVO.

(5) Anonyme Nutzung. Im registrierungsfreien Live-Einzelchat werden keine personenbezogenen Daten der ratsuchenden Person erhoben, solange diese nicht von sich aus identifizierende Angaben macht. Insoweit ist der Anwendungsbereich des KDG (der DSGVO) nicht eröffnet; sobald die ratsuchende Person im Gesprächsverlauf personenbezogene Angaben macht, gilt die Rechtsgrundlage nach Absatz 4. Die Einordnung folgt dabei dem Zugangsweg und dem Kontostatus, nicht dem angezeigten Namen.

7.3 Daten der Beratenden und der administrativen Rollen

Die Verarbeitung der Konto-, Rollen- und Zuordnungsdaten der Beratenden sowie der administrativen Rollen beruht auf dem berechtigten Interesse nach § 6 Abs. 1 lit. g KDG sowie auf dem kirchlichen Interesse nach § 6 Abs. 1 lit. f KDG an einer einheitlichen, sicheren und für alle angeschlossenen Träger gemeinsam betriebenen Beratungsplattform. Eine Einwilligung ist nicht die tragende Grundlage, weil die Nutzung der Plattform Bestandteil der beruflichen bzw. ehrenamtlichen Tätigkeit ist und eine Freiwilligkeit im datenschutzrechtlichen Sinne insoweit nicht vorliegt.

Preset-Hinweis (einzige inhaltliche Abweichung). Das kirchliche Interesse nach § 6 Abs. 1 lit. f KDG hat kein Pendant in der DSGVO. Im DSGVO-Preset ist dieser Abschnitt daher umzuformulieren: Die Verarbeitung stützt sich dort auf Art. 6 Abs. 1 lit. b DSGVO (Erfüllung des Beschäftigungs- oder Tätigkeitsverhältnisses, soweit die beratende Person beim Verantwortlichen beschäftigt ist) und im Übrigen auf Art. 6 Abs. 1 lit. f DSGVO; bei Beschäftigten ist zusätzlich die nationale Beschäftigtendatenschutzvorschrift heranzuziehen. Alle übrigen Abschnitte dieses Kapitels sind preset-neutral und wechseln nur die Normanker.

Beschäftigtendatenschutz. Zwei Verarbeitungen berühren die Beschäftigtenperspektive besonders und sind gesondert zu würdigen: Erstens die pseudonymisierte Nachrichtenstatistik, die je versendeter Nachricht eine Zeile erzeugt und damit ein Tätigkeitsprofil ermöglicht; sie ist so ausgestaltet, dass Beratende ausschließlich ihre eigenen Kennzahlen einsehen und aggregierte Auswertungen einer Kleinstzellen-Unterdrückung unterliegen (Abschnitt 6.15). Zweitens der Übergabegrund „Fachkraft erkrankt“, der ein Gesundheitsdatum der beratenden Person darstellt und zusätzlich an § 11 KDG / Art. 9 DSGVO zu messen ist. Beide Punkte sind mit der jeweils zuständigen Mitarbeitervertretung abzustimmen.

7.4 Daten der Träger-Vertreter:innen

Die im Rahmen der Auftragsverarbeitungsvereinbarung erhobenen Angaben der unterzeichnenden Personen (Name, Funktion, Organisation, E-Mail-Adresse, Signaturstatus und -zeitpunkt) dienen der Erfüllung einer rechtlichen Verpflichtung nach § 6 Abs. 1 lit. c i. V. m. § 29 KDG / Art. 6 Abs. 1 lit. c i. V. m. Art. 28 DSGVO. Die Betroffenen sind regelmäßig keine Nutzer:innen der Beratungsanwendung; sie unterzeichnen über personalisierte, zeitlich befristete Links. Sie bilden damit einen eigenständigen Betroffenenkreis mit eigenem Verarbeitungszweck. Unterzeichnete Signaturen werden zu Nachweiszwecken aufbewahrt; abgelehnte Signaturen werden nach einer konfigurierten Frist gelöscht.

7.5 Protokoll- und Nachweisdaten

Zugriffs-, Einladungs-, Übergabe- und Support-Protokolle dienen der Nachweisbarkeit nach § 7 Abs. 1 KDG / Art. 5 Abs. 2 DSGVO sowie der Sicherheit der Verarbeitung nach § 26 KDG / Art. 32 DSGVO. Rechtsgrundlage ist § 6 Abs. 1 lit. c und lit. g KDG / Art. 6 Abs. 1 lit. c und lit. f DSGVO. Da diese Daten eigenen Aufbewahrungszwecken dienen, sind sie von Löschanträgen betroffener Personen ausgenommen und unterliegen einer eigenen, im Löschkonzept festzulegenden Frist.

Für mehrere Protokollbestände ist eine solche Frist derzeit nicht definiert (Abschnitt 6.18); dies ist als Maßnahme geführt, weil eine unbefristete Aufbewahrung ohne festgelegten Zweck der Speicherbegrenzung nach § 7 Abs. 1 lit. e KDG / Art. 5 Abs. 1 lit. e DSGVO widerspräche.

7.6 Nicht in Anspruch genommene Rechtsgrundlagen

Ausdrücklich nicht in Anspruch genommen werden: Verarbeitungen zu Werbe- oder Marketingzwecken, Profilbildung, automatisierte Entscheidungen im Einzelfall nach § 24 KDG / Art. 22 DSGVO sowie jede Weitergabe von Beratungsinhalten an Dritte zu eigenen Zwecken des Betreibers oder seiner Dienstleister. Eine Übermittlung von Beratungsinhalten an Sprachmodell- oder sonstige KI-Dienste findet nicht statt; die vorhandene Übersetzungsfunktion betrifft ausschließlich redaktionelle Rechtstexte (Abschnitt 6.17).

Kapitel 8

Betroffenenrechte

8.1 Identitätsüberprüfung

Organisatorischer Teil — vom Plattformbetreiber gepflegt (Vertragsunterlagen) — Bearbeitung im Administrationsbereich folgt —

Dieser Abschnitt beschreibt die Organisation, die Entscheidungswege und die juristische Abwägung des Trägers. Er ist aus Quellcode nicht ableitbar und wird deshalb nicht von ORISO gepflegt. Bis der Träger ihn verfasst, trägt das Dokument hier nur den eingeklappten Entwurfstext; die eckigen Klammern darin sind bewusst offene Stellen.

Entwurfstext einblenden

Vor der Bearbeitung eines Betroffenenantrags ist die Identität der antragstellenden Person zu überprüfen. Beim Plattformbetreiber ist diese Prüfung beinahe unmöglich: Die Plattform kennt weder Klarnamen noch verifizierte Kontaktdaten, sondern lediglich ein systemgeneriertes Pseudonym und gegebenenfalls eine freiwillig hinterlegte, nicht verifizierte E-Mail-Adresse. Der Betreiber ermittelt daher die zuständige Beratungsstelle und bittet diese um die Prüfung; die Beratungsstelle gleicht die vorliegenden Angaben mit dem ihr bekannten Beratungsverlauf ab und bestätigt die Zuordnung über [Kanal, z. B. Rückmeldung im Beratungsschat]. Ergänzend kommen in Betracht: [weitere Legitimationsmittel, z. B. Rückbestätigung über die hinterlegte E-Mail-Adresse, Nennung fallbezogener Merkmale]. Bestehen begründete Zweifel an der Identität, werden nach § 17 Abs. 3 KDG / Art. 12 Abs. 6 DSGVO zusätzliche Informationen angefordert; kann die Identität nicht festgestellt werden, wird der Antrag mit Begründung abgelehnt. Zuständig für die Durchführung ist [Stelle/Funktion], Bearbeitungsfrist ist [Frist].

8.3 Datenschutzhinweise und Informationswege

Organisatorischer Teil — vom Plattformbetreiber gepflegt (Vertragsunterlagen) — Bearbeitung im Administrationsbereich folgt —

Dieser Abschnitt beschreibt die Organisation, die Entscheidungswege und die juristische Abwägung des Trägers. Er ist aus Quellcode nicht ableitbar und wird deshalb nicht von ORISO gepflegt. Bis der Träger ihn verfasst, trägt das Dokument hier nur den eingeklappten Entwurfstext; die eckigen Klammern darin sind bewusst offene Stellen.

Entwurfstext einblenden

Die Datenschutzhinweise nach §§ 15 und 16 KDG / Art. 13 und 14 DSGVO sind vor der Registrierung auf der Registrierungsseite sowie nach der Anmeldung dauerhaft in der Anwendung

verlinkt; für den registrierungsfreien Live-Chat werden sie auf der vorgeschalteten Einstiegsseite angezeigt. Impressum, Datenschutzerklärung und Einwilligungstext bestehen auf jeder Ebene der Plattform; pflegt eine Beratungsstelle keine eigene Fassung, gilt die des Trägers, andernfalls die Plattform-Vorlage — Ratsuchende sehen damit stets einen vollständigen Satz Rechtstexte. Über ihre eigene Verarbeitung — insbesondere die Falldokumentation außerhalb der Plattform — informieren die Beratungsstellen selbst, und zwar über [Kanal, z. B. Hinweis im Beratungsschat, Dokument-Upload, Verlinkung der eigenen Datenschutzerklärung]. Änderungen der Datenschutzhinweise werden [Verfahren, z. B. über einen Hinweis beim nächsten Anmelden] bekannt gemacht. Für Rückfragen steht [Kontaktkanal] zur Verfügung.

Technischer Teil — von ORISO gepflegt — Abschnitte 8.1, 8.3 und 8.11 sind organisatorisch —

Die Betroffenenrechte nach §§ 14 ff. KDG / Art. 12 ff. DSGVO können bei jedem gemeinsam Verantwortlichen geltend gemacht werden; die interne Zuteilung regelt die Vereinbarung über die gemeinsame Verantwortlichkeit. Die nachfolgenden Abschnitte beschreiben je Recht, was technisch möglich ist und was technisch nicht möglich ist. Diese Trennung ist bewusst so scharf gezogen: Die durchgängige Ende-zu-Ende-Verschlüsselung, die weitgehende Datenminimierung und das Selbstlöschungsmodell erweitern die Rechte der Betroffenen an mehreren Stellen erheblich, setzen ihnen an anderen Stellen aber eine technische Grenze, die auch mit organisatorischem Aufwand nicht zu überwinden ist.

Die Abschnitte 8.1 (Identitätsüberprüfung), 8.2 (Besonderheiten bei anonymer Nutzung), 8.3 (Datenschutzhinweise) und 8.11 (Datenweitergabe an Ermittlungsbehörden) sind betreiberspezifisch und werden vom Verantwortlichen gepflegt; für 8.1, 8.3 und 8.11 stehen vorausgefüllte Entwürfe bereit.

8.4 Recht auf Auskunft (§ 17 KDG / Art. 15 DSGVO)

Technisch möglich. Der Plattformbetreiber kann über die bei ihm gespeicherten Stamm- und Systemdaten Auskunft erteilen. Dies sind im Wesentlichen: das systemgenerierte Pseudonym, eine etwaig hinterlegte E-Mail-Adresse, die Postleitzahl, die Zuordnung zu Beratungsstelle und Fachbereich, die gewählten Beratungsthemen und fachbereichsbezogenen Angaben, die Zeitpunkte der Registrierung sowie der Zustimmung zu Nutzungsbedingungen und Datenschutzhinweisen, der Status der Zwei-Faktor-Authentisierung, Spracheinstellung und Benachrichtigungseinstellungen, die Metadaten der Beratungssitzungen (Anlage, Zuweisung, Archivierung), die Einträge im Benachrichtigungsverlauf sowie die zu ihrer Person geführten Protokolleinträge des Fallübergabeverfahrens.

Technisch nicht möglich. Über die Inhalte der Beratungskommunikation — Nachrichten, Dateien, Sprachnachrichten, Video- und Audiogespräche — kann der Plattformbetreiber keine Auskunft erteilen. Sie liegen ausschließlich als Chiffre vor; die zur Entschlüsselung erforderlichen Schlüssel befinden sich allein auf den Endgeräten der Gesprächsbeteiligten (Abschnitt 6.9). Der Betreiber kann diese Inhalte weder lesen noch ausleiten noch in eine Auskunft aufnehmen. Ratsuchende haben die Inhalte demgegenüber in ihrer Anwendung vollständig und jederzeit vor Augen; die Auskunft über den Beratungsinhalt erfolgt damit faktisch durch die Anwendung selbst und, soweit erforderlich, durch die beratende Stelle.

Ehrlich zu benennende Grenze. Zwei Bestände verdienen besondere Erwähnung, weil sie Daten über eine ratsuchende Person außerhalb ihres eigenen Beratungsraums enthalten: die Team-Besprechung, in der Berater:innen eine noch nicht angenommene Anfrage untereinander erörtern, und der Begründungsfreitext des Fallübergabeverfahrens. Beide sind der ratsuchenden Person nicht sichtbar. Der Übergabefreitext ist beim Verantwortlichen im Klartext verfügbar und daher auskunftsfähig; die Inhalte der Team-Besprechung sind es aus denselben kryptografischen Gründen nicht wie die Beratungsinhalte selbst — auskunftsfähig sind insoweit nur die Metadaten (Bestehen des Raums, Zeitpunkt, teilnehmende Fachkräfte). Für den Auskunftsanspruch bedeutet dies: Die Auskunft ist zu erteilen, sie kann den Inhalt der kollegialen Erörterung aber nicht umfassen. Diese Einschränkung ist im Auskunftsschreiben ausdrücklich zu benennen; sie darf nicht durch eine pauschale Formulierung verdeckt werden.

Verfahrenshinweis. Da die Auskunft die Identität der antragstellenden Person voraussetzt, die Plattform diese aber bewusst nicht kennt, ist die Identitätsprüfung nach Abschnitt 8.1 vorgelagert und praktisch nur über die Beratungsstelle zu leisten.

8.5 Recht auf Berichtigung (§ 18 KDG / Art. 16 DSGVO)

Technisch möglich. Ratsuchende können ihre E-Mail-Adresse, ihr Passwort, die Spracheinstellung, die Benachrichtigungseinstellungen und den zweiten Faktor selbst und unmittelbar in der Anwendung ändern. Beratende und administrative Rollen lassen Namensangaben, dienstliche E-Mail-Adresse, Abwesenheitshinweis und Zuordnungen über ihre Administration ändern.

Praktisch begrenzt. Die übrigen Angaben sind entweder systemseitig erzeugt (das Pseudonym, die Kontokennung) oder dokumentieren die tatsächliche Systemnutzung (Zeitstempel, Sitzungsstatus, Protokolleinträge). Solche Dokumentationsdaten sind einer Berichtigung nicht zugänglich, weil eine Änderung den dokumentierten Vorgang unrichtig machen würde; sie unterliegen stattdessen der Löschung nach Fristablauf. Die Postleitzahl ist änderbar, ihre inhaltliche Richtigkeit wird systemseitig ohnehin nicht geprüft.

Technisch nicht möglich. Eine Berichtigung von Beratungsinhalten durch den Plattformbetreiber ist ausgeschlossen. Ratsuchende können eigene Nachrichten jedoch selbst löschen und neu senden; das ist der praktisch wirksamere Weg.

8.6 Recht auf Löschung (§ 19 KDG / Art. 17 DSGVO)

Technisch möglich — besonders datenschutzfreundlich ausgestaltet. Ratsuchende können einzelne Nachrichten sowie ihr gesamtes Konto selbstständig und unmittelbar löschen; einer Antragstellung beim Verantwortlichen bedarf es dafür nicht. Die Kontolöschung durchläuft ein Schutzfenster von 48 Stunden mit ausschließlich lesendem Zugriff — es dient dem Schutz vor Fehlbedienung — und wird anschließend automatisiert vollzogen. Der Löschlauf entfernt Identitätskonto, Chat-Konto (einschließlich ausdrücklichem Löschkennzeichen und Bereinigung der Räume auf dem Chat-Server), Sitzungen und Sitzungszusatzdaten, Themen- und Supervisionszuordnungen, Fallübergabe-Anträge, Agenturzuordnungen, den Eintrag in der Pseudonym-Registrierung, mobile Gerätekennungen und schließlich den Kontodatensatz. Anonyme Konten werden ohne Zutun der betroffenen Person nach kurzer Frist automatisiert gelöscht.

Beratende werden im Rahmen ihrer Einführung darauf hingewiesen, dass Beratungsdaten jederzeit und ohne Ankündigung durch die ratsuchende Person entfernt werden können.

Technisch nicht möglich. Der Serverbetreiber kann eine einzelne Nachricht innerhalb eines verschlüsselten Verlaufs nicht identifizieren und daher nicht gezielt löschen; er kann jedoch vollständige Räume samt Medien entfernen. Die Löschung einzelner Nachrichten erfolgt deshalb ausschließlich durch die betroffene Person selbst in der Anwendung.

Ehrlich zu benennende Grenzen.

Nicht erfasste Bestände. Der Konto-Löschlauf erfasst derzeit nicht: den In-App-Benachrichtigungsverlauf, serverseitig gespeicherte Nachrichtenentwürfe, die pseudonymisierte Nachrichtenstatistik der Beratenden, das Archiv versendeter Einladungs-Mails, das Prüfprotokoll der Inaktivitätsbenachrichtigungen sowie eine aus der Migration verbliebene Zuordnungstabelle zwischen Person und Chat-Raum. Das Schließen dieser Lücken ist als Maßnahme geführt (Abschnitt 6.18); bis dahin ist die Löschung nicht vollständig und darf nicht als solche beschrieben werden.

Verweisdatensatz nach der Löschung. Nach dem Vollzug verbleibt ein Verweisdatensatz mit der vollständigen früheren Kontokennung, damit Verweise in fortbestehenden Datensätzen aufgelöst werden können. Der Personenbezug überdauert damit die Löschung. Für diesen Datensatz ist eine Frist festzulegen oder die Kennung ihrerseits zu pseudonymisieren.

Sicherungen. Gelöschte Daten bestehen bis zum Ablauf der Sicherungsfristen (30 Tage Vollsicherung, sieben Tage fortlaufende Protokollsicherung des Chat-Dienstes) in den Sicherungen fort. Das ist bei zeitlich gestaffelten Sicherungen üblich und im Löschkonzept auszuweisen.

Protokoll- und Nachweisdaten. Protokoll- und Nachweisdaten mit eigener Rechtsgrundlage und eigener Frist sind von Löschanträgen ausgenommen (Abschnitt 7.5).

Beratende. Konten Beratender können während der aktiven Tätigkeit nicht gelöscht werden; maßgeblich ist insoweit die Beendigung des Tätigkeitsverhältnisses beim Träger.

Team-Besprechungs-Archiv. Der geschlossene Besprechungsraum bleibt lesend erhalten; eine Aufbewahrungsfrist ist festzulegen.

8.7 Recht auf Einschränkung der Verarbeitung (§ 20 KDG / Art. 18 DSGVO)

Technisch nicht umsetzbar in der eigentlichen Form. Eine Kennzeichnung von Daten als „nur gespeichert, aber nicht verarbeitet“ sieht die Plattform nicht vor; eine solche Kennzeichnung wäre bei Ende-zu-Ende-verschlüsselten Inhalten auch wirkungslos, weil der Verantwortliche sie ohnehin nicht verarbeitet.

Technisch möglich als funktionale Entsprechung. Zur Verfügung stehen: die Aussetzung des Löschvorgangs für drei bis höchstens zwölf Monate mit dokumentiertem Grund — sie hält den Bestand unverändert, ohne ihn zu löschen —, das Lesefenster von 48 Stunden im Löschlauf, in dem keine schreibende Verarbeitung mehr stattfindet, sowie die Sperrung oder Löschung des Kontos über den Verantwortlichen. Für Beratende steht zusätzlich die vorübergehende Deaktivierung des Kontos zur Verfügung; sie ist die praktisch nächstliegende Entsprechung einer Einschränkung.

Ratsuchende können ihr Konto selbst nicht sperren, sondern nur löschen. Ein Antrag auf Einschränkung ist daher an den Verantwortlichen zu richten, der die Sperrung veranlasst.

8.8 Recht auf Datenübertragbarkeit (§ 22 KDG / Art. 20 DSGVO)

Technisch möglich. Die auf Einwilligung gestützten Stammdaten (Pseudonym, E-Mail-Adresse, Postleitzahl, Themen- und Fachbereichszuordnung, freiwillige Zusatzangaben, Zeitpunkte der Zustimmungen) lassen sich in einem strukturierten, gängigen und maschinenlesbaren Format bereitstellen.

Technisch nicht möglich. Ein maschinenlesbarer Export der Beratungsinhalte durch den Verantwortlichen scheidet aus, weil dieser sie nicht entschlüsseln kann. Ratsuchende können die Inhalte in ihrer Anwendung vollständig einsehen und auf ihrem Endgerät sichern; eine serverseitig erzeugte Ausleitung existiert nicht. Ein clientseitiger Export der entschlüsselten Historie ist als mögliche Produktmaßnahme zu prüfen, derzeit jedoch nicht umgesetzt. Die Einschränkung ist die unmittelbare Kehrseite der Verschlüsselung — sie ist der Preis für einen Schutz, der ohne sie nicht bestünde, und wird daher offen ausgewiesen statt beschönigt.

Für Beratende ist das Recht regelmäßig nicht einschlägig, weil ihre Daten weder auf Einwilligung noch auf einem mit ihnen geschlossenen Vertrag mit dem Plattformbetreiber beruhen.

8.9 Recht auf Widerspruch (§ 23 KDG / Art. 21 DSGVO)

Praktisch enger Anwendungsbereich. Der Widerspruch richtet sich gegen Verarbeitungen auf Grundlage berechtigter Interessen. Bei Ratsuchenden betrifft dies allein die technischen Nutzungs- und Betriebsdaten (Abschnitt 7.2 Absatz 1). Diese sind für den Betrieb zwingend erforderlich; ein Widerspruch führte dazu, dass die Plattform nicht mehr genutzt werden kann. Er läuft damit auf die Beendigung der Nutzung — und damit auf das Löschrrecht nach Abschnitt 8.6 — hinaus.

Verarbeitungen zu Werbe- oder Marketingzwecken, gegen die ein voraussetzungsloser Widerspruch bestünde, finden nicht statt.

Bei Beratenden überwiegen regelmäßig zwingende schutzwürdige Gründe des Verantwortlichen, weil ohne Konto, Rollenzuordnung und Protokollierung weder Beratung noch deren Nachweisbarkeit möglich sind. Ein Widerspruch ist im Einzelfall zu prüfen, insbesondere bei der Tätigkeitsstatistik (Abschnitt 6.15), bei der die Abwägung wegen des Leistungsbezugs sorgfältig zu dokumentieren ist.

8.10 Recht auf Widerruf der Einwilligung (§ 8 Abs. 6 KDG / Art. 7 Abs. 3 DSGVO)

Technisch möglich und unmittelbar wirksam. Der Widerruf kann gegenüber der Beratungsstelle oder gegenüber dem Plattformbetreiber erklärt werden. Da die Registrierung und die Beratung auf Einwilligung beruhen, entzieht der Widerruf ihnen die Grundlage; er wird durch die Löschung des Kontos unmittelbar vollzogen, die die betroffene Person selbst auslösen kann. Teilwiderrufe sind für die freiwilligen Zusatzangaben möglich: Die E-Mail-Adresse und die Zwei-Faktor-Authentisierung lassen sich jederzeit selbst entfernen.

Die Rechtmäßigkeit der bis zum Widerruf erfolgten Verarbeitung bleibt unberührt. Für Beratende ist das Widerrufsrecht nicht einschlägig, weil ihre Datenverarbeitung nicht auf Einwilligung beruht (Abschnitt 7.3).

Nachweis der Einwilligung — offener Punkt. Die Zustimmung zu Nutzungsbedingungen und Datenschutzhinweisen wird mit Zeitstempel gespeichert. Für einen Teil des Registrierungsflusses ist eine ausschließlich clientseitige Prüfung der Bestätigung dokumentiert; ein serverseitig erzwungener Nachweis ist zur Erfüllung der Nachweispflicht nach § 8 Abs. 2 KDG / Art. 7 Abs. 1 DSGVO sicherzustellen. Dieser Punkt ist als Maßnahme geführt.

8.12 Zusammenfassende Bewertung je Recht

| Recht | Norm KDG (DSGVO) | Umsetzbarkeit

| Auskunft | § 17 KDG (Art. 15) | eingeschränkt — Stamm- und Systemdaten ja, Beratungsinhalte technisch nicht

| Berichtigung | § 18 KDG (Art. 16) | eingeschränkt — änderbare Felder selbst pflegbar, Dokumentationsdaten nicht berichtigungsfähig

| Löschung | § 19 KDG (Art. 17) | weitgehend — Selbstlöschung von Nachrichten und Konto; benannte Restbestände offen

| Einschränkung | § 20 KDG (Art. 18) | eingeschränkt — nur Sperrung, Löschaussetzung oder Deaktivierung

| Datenübertragbarkeit | § 22 KDG (Art. 20) | eingeschränkt — Stammdaten exportierbar, Beratungsinhalte nicht

| Widerspruch | § 23 KDG (Art. 21) | praktisch kaum einschlägig — Betriebsdaten zwingend erforderlich

| Widerruf | § 8 Abs. 6 KDG (Art. 7 Abs. 3) | vollständig — unmittelbar durch Selbstlöschung vollziehbar

8.11 Eskalationskette und Datenweitergabe an Ermittlungsbehörden

Organisatorischer Teil — vom Plattformbetreiber gepflegt (Vertragsunterlagen) — Bearbeitung im Administrationsbereich folgt —

Dieser Abschnitt beschreibt die Organisation, die Entscheidungswege und die juristische Abwägung des Trägers. Er ist aus Quellcode nicht ableitbar und wird deshalb nicht von ORISO gepflegt. Bis der Träger ihn verfasst, trägt das Dokument hier nur den eingeklappten Entwurfstext; die eckigen Klammern darin sind bewusst offene Stellen.

Entwurfstext einblenden

Für den Fall, dass im Beratungsverlauf eine anzeigepflichtige Straftat angekündigt oder eine akute Gefährdung erkennbar wird („Worst-Case-Fall“), besteht eine gemeinsam erarbeitete Handlungsempfehlung mit folgender Verantwortungskette: (1) Die beratende Person informiert unverzüglich [Leitung der Beratungsstelle]; (2) es erfolgt eine fachliche Gefährdungseinschätzung durch [Funktion], erforderlichenfalls unter Hinzuziehung von [Fachdienst]; (3) liegen die Voraussetzungen des § 138 StGB oder eine Kindeswohlgefährdung vor, leitet die Beratungsstelle — nicht der Plattformbetreiber — die erforderlichen Angaben an [Polizei / Jugendamt] weiter; (4) parallel werden [Referatsleitung, Datenschutzbeauftragung, Trägervvertretung] informiert. Weitergegeben werden können ausschließlich der von der beratenden Person eingesehene Nachrichteninhalt, der systemseitig vermerkte Zeitpunkt und die Anschrift des Auftragsverarbeiters; IP-Adressen der Ratsuchenden werden in den Fachdatenbeständen nicht geführt und können daher nicht herausgegeben werden, und Beratungsinhalte liegen dem Plattformbetreiber wegen der Ende-zu-Ende-Verschlüsselung nicht im Klartext vor. Für Datenschutzvorfälle nach § 33 KDG / Art. 33 DSGVO gilt gesondert: Meldung an [Aufsicht] binnen 72 Stunden über [Meldeweg], interne Alarmierung von [Funktionen] binnen [Frist], Vertretung durch [Funktion].

Kapitel 9

Verhältnismäßigkeit

9.1 Legitimer Zweck

Organisatorischer Teil — vom Plattformbetreiber gepflegt (Vertragsunterlagen) — Bearbeitung im Administrationsbereich folgt —

Dieser Abschnitt beschreibt die Organisation, die Entscheidungswege und die juristische Abwägung des Trägers. Er ist aus Quellcode nicht ableitbar und wird deshalb nicht von ORISO gepflegt. Bis der Träger ihn verfasst, trägt das Dokument hier nur den eingeklappten Entwurfstext; die eckigen Klammern darin sind bewusst offene Stellen.

Entwurfstext einblenden

Die Verarbeitung verfolgt den Zweck, ratsuchenden Menschen eine niedrigschwellige, vertrauliche und ortsunabhängige Beratung zu ermöglichen. [Name des Verantwortlichen] nimmt damit seinen [satzungsmäßigen / gesetzlichen / kirchlichen] Auftrag wahr, Menschen in Not- und Konfliktlagen zu unterstützen; Grundlage ist [Verweis auf Leitbild, Satzung oder gesetzlichen Auftrag]. Der Zweck ist legitim, weil er dem Abbau von Zugangsbarrieren dient: Erreicht werden insbesondere Personen, die eine Beratungsstelle aus Scham, aus Mobilitätsgründen, wegen zeitlicher Zwänge oder aus Angst vor Stigmatisierung nicht aufsuchen würden. Ergänzend verfolgt die Verarbeitung das Ziel, die Beratung digital in der Qualität und Vertraulichkeit anzubieten, die auch für die Beratung vor Ort gilt.

9.2 Geeignetheit

Organisatorischer Teil — vom Plattformbetreiber gepflegt (Vertragsunterlagen) — Bearbeitung im Administrationsbereich folgt —

Dieser Abschnitt beschreibt die Organisation, die Entscheidungswege und die juristische Abwägung des Trägers. Er ist aus Quellcode nicht ableitbar und wird deshalb nicht von ORISO gepflegt. Bis der Träger ihn verfasst, trägt das Dokument hier nur den eingeklappten Entwurfstext;

die eckigen Klammern darin sind bewusst offene Stellen.

Entwurfstext einblenden

Die Verarbeitung ist zur Erreichung des Zwecks geeignet. Eine zentrale, unter einem eingeführten Namen auffindbare und pseudonym nutzbare Plattform erreicht nachweislich Personen, die andernfalls keine Hilfe in Anspruch nähmen; dies belegen [Kennzahlen, z. B. Anzahl der Erstanfragen, Anteil anonymer Erstkontakte, Erhebung/Evaluation vom [Datum]]. Die eingesetzten technischen Verfahren sind geeignet, die zugesagte Vertraulichkeit tatsächlich herzustellen: Beratungsinhalte werden Ende-zu-Ende-verschlüsselt übertragen und gespeichert, sodass sie weder dem Betreiber noch seinen Dienstleistern zugänglich sind. Die einheitliche Plattform ermöglicht zudem ein gemeinsames Qualitäts-, Sicherheits- und Fortbildungsniveau, das einzelne Träger jeweils für sich nicht erreichen könnten.

9.3 Erforderlichkeit

Organisatorischer Teil — vom Plattformbetreiber gepflegt (Vertragsunterlagen) — Bearbeitung im Administrationsbereich folgt —

Dieser Abschnitt beschreibt die Organisation, die Entscheidungswege und die juristische Abwägung des Trägers. Er ist aus Quellcode nicht ableitbar und wird deshalb nicht von ORISO gepflegt. Bis der Träger ihn verfasst, trägt das Dokument hier nur den eingeklappten Entwurfstext; die eckigen Klammern darin sind bewusst offene Stellen.

Entwurfstext einblenden

Ein milderer, gleich geeignetes Mittel steht nicht zur Verfügung. Geprüft und verworfen wurden: (1) der Verzicht auf jede Registrierung — er würde eine kontinuierliche, über mehrere Kontakte hinweg getragene Beratung und den Aufbau eines Vertrauensverhältnisses unmöglich machen; für den Erstkontakt bleibt der registrierungsfreie Live-Chat als mildere Variante erhalten; (2) dezentrale Einzellösungen der Träger — sie fragmentieren das Angebot, überfordern kleinere Träger technisch und finanziell und schwächen die Auffindbarkeit für Ratsuchende erheblich; (3) [weitere geprüfte Alternative, z. B. reine Telefon- oder Vor-Ort-Beratung] — [Begründung der Verwerfung]. Der Umfang der erhobenen Daten ist auf das Erforderliche begrenzt: Pflichtangabe ist allein die Postleitzahl zur Zuordnung der zuständigen Beratungsstelle; der Benutzername wird systemseitig erzeugt, alle weiteren Angaben sind freiwillig.

9.4 Angemessenheit

Organisatorischer Teil — vom Plattformbetreiber gepflegt (Vertragsunterlagen) — Bearbeitung im Administrationsbereich folgt —

Dieser Abschnitt beschreibt die Organisation, die Entscheidungswege und die juristische Abwägung des Trägers. Er ist aus Quellcode nicht ableitbar und wird deshalb nicht von ORISO gepflegt. Bis der Träger ihn verfasst, trägt das Dokument hier nur den eingeklappten Entwurfstext; die eckigen Klammern darin sind bewusst offene Stellen.

Entwurfstext einblenden

Die Interessenabwägung fällt zugunsten der Verarbeitung aus. Für die Betroffenen streiten die Sensibilität der Beratungsinhalte und die besondere Schutzbedürftigkeit eines Teils der Ratsuchenden; für die Verarbeitung streiten der Nutzen des Angebots und die Tiefe der ergriffenen Schutzmaßnahmen. Maßgeblich sind vier Gesichtspunkte: (1) Freiwilligkeit — die Nutzung, die Registrierung und sämtliche Zusatzangaben sind freiwillig, ein Widerruf ist jederzeit und unmittelbar wirksam; (2) Datenminimierung — der Benutzername wird systemseitig erzeugt, Pflichtangabe ist allein die Postleitzahl, es findet weder Tracking noch Profilbildung noch Werbung statt; (3) begrenzte Verarbeitungstätigkeiten — der Betreiber wertet Beratungsdaten nicht aus, Statistiken sind aggregiert und mit einer Kleinstzellen-Unterdrückung versehen; (4) umfangreiche technische und organisatorische Maßnahmen — insbesondere die durchgängige

Ende-zu-Ende-Verschlüsselung aller Beratungsformen, die Selbstlöschung von Nachrichten und Konten, die verpflichtende Zwei-Faktor-Authentisierung der Beratenden und das protokollierte Übergabeverfahren. Die verbleibenden Risiken und die ihnen zugeordneten Maßnahmen sind in der Risikoanalyse (Anlage 1) im Einzelnen ausgewiesen; als noch nicht abschließend behandelt gelten [Aufzählung der aus Kapitel 10 übernommenen offenen Punkte].

Kapitel 10

Ergebnis der Datenschutz-Folgenabschätzung

Technischer Teil — von ORISO gepflegt —

Die Verarbeitungstätigkeit „Bereitstellung und technischer Betrieb der Online-Beratungsplattform“ kann in der in Kapitel 6 beschriebenen Ausgestaltung umgesetzt werden — unter Beachtung der Maßnahmen aus der Risikoanalyse (Anlage 1) und der Fristen des Löschkonzepts (Anlage 2). Ohne diese beiden Anlagen ist das Ergebnis inhaltlich unvollständig; die Freigabe steht unter dem Vorbehalt der dort festgelegten Maßnahmen.

Tragend für dieses Ergebnis sind die technischen Schutzmaßnahmen, die den Zugriff des Verantwortlichen und seiner Auftragsverarbeiter auf die eigentlichen Beratungsinhalte ausschließen: die durchgängige, nicht abschaltbare Ende-zu-Ende-Verschlüsselung aller Beratungsformen einschließlich Dateien, Sprachnachrichten und Medienströmen, die Datenminimierung durch systemgenerierte Pseudonyme, der vollständige Verzicht auf Tracking und Drittanbieter-Telemetrie, die deaktivierte Föderation, die Selbstlöschung von Nachrichten und Konten sowie die Kleinstzellen-Unterdrückung und die Pseudonymisierung in der Statistik. Gegenüber der Vorgängerplattform stellt dies in den zentralen Punkten — Nachrichten, Dateien, Video und anonymer Live-Chat — eine wesentliche Verbesserung des Schutzniveaus dar.

Zugleich ist dieses Ergebnis ausdrücklich bedingt. Es setzt voraus, dass die in dieser DSFA offen benannten Punkte vor dem Produktivbetrieb abgearbeitet werden. Als Bedingungen sind festzuhalten:

Klärung des Sicherungspfads in ein externes Quellcode-Verwaltungssystem (Abschnitt 6.17). Ist dieser Pfad aktiv, liegt eine unzulässige Drittlandübermittlung mit praktisch unlöschbarer Historie vor; die Freigabe entfällt bis zur Abschaltung.

Schließen der Löschlücken und Festlegung von Aufbewahrungsfristen für die in Abschnitt 6.18 benannten Bestände, für die Protokolldaten und für die Medien des Chat-Dienstes.

Härtung des Betriebs des Chat-Dienstes: Abschaltung der offenen Registrierung, Wiederherstellung der Ratenbegrenzungen, authentifizierte Medien-Downloads, Entscheidung über die Deaktivierung des Online-Status.

Trennung von Betriebs- und Einsichtsrechten der Plattform-Administration sowie ausschließlich schreibender Umgang mit Zugangsdaten der Träger und deren Verschlüsselung im Ruhezustand (Abschnitt 6.16).

Ersetzung der externen STUN-Server und Aktivierung des IP-freien Protokoll-Zuhörers im Identitätsmanagement (Abschnitte 6.6 und 6.10).

Nachweis der Konfiguration des Identitätsmanagements am Live-System (Passwortrichtlinie, Anmeldeschutz, Token-Laufzeiten, Zwei-Faktor-Erzwingung) und Angleichung der DSFA an den nachgewiesenen Stand (Abschnitt 6.5).

Klärung der offenen Betreiberfragen mit dem Hostinganbieter: Verschlüsselung ruhender Daten, Speicherort und Verschlüsselung der Sicherungen, Zugriffs- und Adminkonzept der Produktivumgebung, Unterauftragsverarbeiter. Ohne diese Antworten bleibt das Kapitel zu den technischen und organisatorischen Maßnahmen unvollständig.

Entscheidung über den Medien-Prüf-Proxy (Abschnitt 6.12): Solange kein automatisierter Scan aktiv ist, verbleibt ein mittleres Restrisiko, das in der Risikoanalyse als solches zu führen und gegenüber den Trägern transparent zu machen ist.

Nicht Gegenstand dieser DSFA sind Funktionen, die zwar entschieden, aber nicht ausgeliefert sind — insbesondere die Terminverwaltung (Abschnitt 6.2.6) und der Medien-Prüf-Proxy. Sie werden bei Auslieferung durch Fortschreibung dieses Dokuments bewertet. Ebenso ist eine Aktivierung der Statistik-Ereignisveröffentlichung, der Push-Benachrichtigungen oder des geparkten Geräts jeweils vor Inbetriebnahme gesondert zu bewerten.

Diese DSFA ist als lebendes Dokument angelegt: Sie wird mit jeder Release-Version fortgeschrieben, und jede technische Aussage ist auf Quellcode, Konfiguration oder Architekturentscheidung zurückführbar. Eine routinemäßige Überprüfung erfolgt zu dem im Dokumentkopf ausgewiesenen Zeitpunkt sowie anlassbezogen bei wesentlichen Änderungen der Verarbeitung.

Die abschließende Bewertung der Verhältnismäßigkeit (Kapitel 9) und die Freigabe durch die Datenschutzbeauftragung des Verantwortlichen sind betreiberseitig zu ergänzen.

Anlage 1

Anlage 1 — Risiken und Maßnahmen (Entwurf)

Technischer Teil — von ORISO gepflegt —

Risiken und Maßnahmen tragen stabile Kennungen (einmal vergeben, nie umnummeriert) und sind dadurch in Vorgängen und Audits präzise referenzierbar. Vollständige Matrix: Anlage 1 — Risikoanalyse (in Vorbereitung). Auszug des Ist-Stands:

Tabelle horizontal scrollbar

| ID | Risiko | Bewertung | Maßnahmen (Ist-Zustand) | Restrisiko

| R-001 | Unbefugte Kenntnisnahme von Beratungsinhalten durch Betreiber oder Dienstleister | hoch | M-001 Megolm-E2EE dauerhaft aktiv, kein unverschlüsselter Sendepfad · M-002 extern auditierte Implementierung (vodozemac) · M-003 AES-256-Dateiverschlüsselung ohne Metadaten-Upload · M-004 Föderation deaktiviert | gering — administrative Serverfunktionen bestehen; Vertraulichkeitsgrenze innerhalb der Beratungsstelle ist Zugriffskontrolle (Abschnitt 5.3/5.7)

| R-002 | Übertragung von Schadsoftware oder rechtswidrigen Bildinhalten über Medien-Uploads | mittel | M-005 Blur + Click-to-Reveal im anonymen Live-Chat (fail-closed-Verdikt, Übergangsmaßnahme) · M-006 Formatvalidierung + Größenlimit redaktioneller Uploads · M-007 fail-closed-Scan-Proxy als beschlossene Zielarchitektur (ADR-019, nicht produktiv) | mittel — bis zur Scanner-Inbetriebnahme

| R-003 | Kontoübernahme durch kompromittierte Anmeldedaten | mittel | M-008 2FA (Authenticator-App/E-Mail-Einmalcode); Einrichtung für Beratende im Einladungsprozess, Befreiung nur dokumentiert · M-009 zentrale, gehashte Passwortspeicherung (Keycloak) | gering

| R-004 | Re-Identifizierung Einzelner aus statistischen Auswertungen | mittel | M-010 ausschließlich Aggregatzahlen mit Kleinstzellen-Unterdrückung (min. 5, fail-closed) · M-011 HMAC-SHA256-Pseudonymisierung der Beraterstatistik | gering

| R-005 | Verlust des Schlüsselmaterials der Nutzer:innen (Unlesbarkeit der eigenen Historie) | mittel | M-012 serverseitiges, verschlüsseltes Schlüssel-Backup; Wiederherstellungsgeheimnis verbleibt beim Nutzer | gering

Anlagen

Anlagenverzeichnis

Organisatorischer Teil — vom Plattformbetreiber gepflegt (Vertragsunterlagen) — Bearbeitung im Administrationsbereich folgt —

Dieser Abschnitt beschreibt die Organisation, die Entscheidungswege und die juristische Abwägung des Trägers. Er ist aus Quellcode nicht ableitbar und wird deshalb nicht von ORISO gepflegt. Bis der Träger ihn verfasst, trägt das Dokument hier nur den eingeklappten Entwurfstext; die eckigen Klammern darin sind bewusst offene Stellen.

Entwurfstext einblenden

Zu dieser Datenschutz-Folgenabschätzung gehören: Anlage 1 — Risikoanalyse (Risiko-/Maßnahmen-Matrix mit stabilen Kennungen je Risiko und Maßnahme, Stand [Datum]); Anlage 2 — Löschkonzept (Aufbewahrungs- und Löschfristen je Datenkategorie einschließlich Protokoll- und Sicherungsdaten, Stand [Datum]); Anlage 3 — Vereinbarung über die gemeinsame Verantwortlichkeit nach § 28 Abs. 1 S. 2 KDG / Art. 26 DSGVO mit ihren Anlagen [Nummern]; Anlage 4 — Auftragsverarbeitungsvereinbarungen mit [Hosting-Betreiber] und [Entwicklungsdienstleister]; Anlage 5 — Verzeichnis der Verarbeitungstätigkeiten nach § 31 KDG / Art. 30 DSGVO, Auszug; Anlage 6 — [Handlungsempfehlung Worst-Case-Fall / weitere Anlage]. Jede Anlage wird eigenständig versioniert; maßgeblich ist der jeweils im Dokumentkopf ausgewiesene Stand.